

Manual 03 - Implementação do Marco de Gestão de Riscos de IA do NIST

CANDIDATO CONTROLADO PARA QA DE PUBLICAÇÃO

Revisão da fonte controlada: 415cb1bb4afcda24109137eca1d6890462458cd8 | Idioma: pt-BR | Linha de base NIST AI RMF 1.0 / NIST AI 100-1; controle de versão e vigilância de fontes obrigatórios.

Limite de asseguarção: Este manual prático de implementação não certifica um sistema de IA, não estabelece conformidade legal, não comprova o alcance de IA confiável nem fornece uma opinião de auditoria.

Caminhos de implementação e modelo operacional

Manual 03 — Caminhos de implementação do NIST AI RMF

Linha de base controlada: NIST AI RMF 1.0 (NIST AI 100-1), com NIST AI 600-1 aplicado quando IA generativa estiver no escopo.

Aviso de versão: O NIST informa que o AI RMF 1.0 está sendo atualizado. Esta entrada de implementação está vinculada à linha de base atualmente publicada do AI RMF 1.0 e deve passar por análise de impacto quando o NIST publicar uma revisão.

1. Escolher o caminho de implementação com base em risco e complexidade

Não escolha um caminho apenas pelo número de empregados. Comece pelo caminho menos complexo que ainda consiga controlar o risco real de IA da organização, seu ciclo de vida, partes afetadas, exposição regulatória, autonomia, escala, dependência de terceiros e consequências potenciais.

Manual 03 memory graphic 1

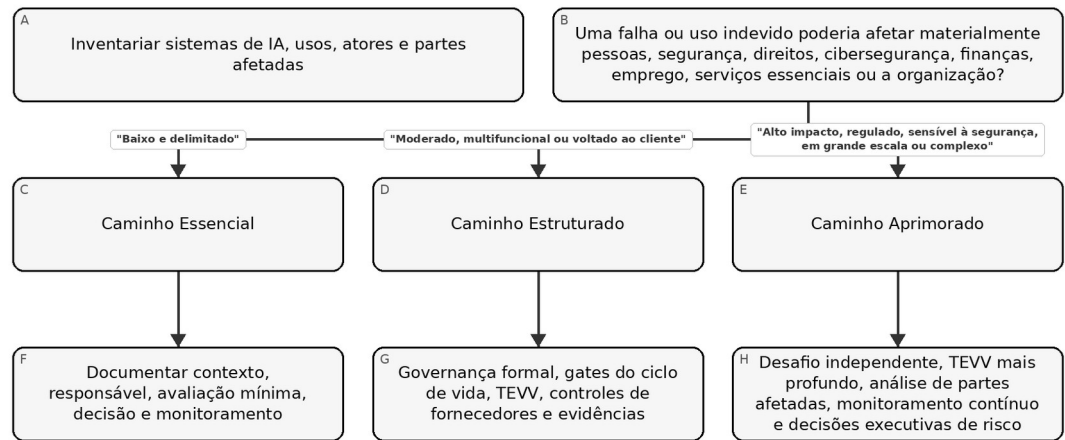


Figura 1. Gráfico de memória de implementação

Explicação acessível: Primeiro, inventarie os sistemas de IA e seu contexto. Usos de baixo risco e escopo limitado podem começar pelo caminho Essencial. Usos moderados, multifuncionais ou voltados ao cliente precisam do caminho Estruturado. Usos de alto impacto, regulados, sensíveis à segurança, em grande escala ou complexos exigem o caminho Aprimorado, com maior independência, avaliação, monitoramento e autoridade de decisão. A organização pode mover um sistema para um caminho mais rigoroso sempre que o risco ou a incerteza aumentar.

Caminho	Contexto típico	Expectativa mínima de governança
Essencial	Organização pequena ou uso de IA delimitado, com consequências limitadas e dependências gerenciáveis	Responsável nomeado, inventário, contexto documentado, revisão básica de risco/impacto, uso aprovado, testes mínimos, orientação ao usuário, monitoramento e rota de incidentes
Estruturado	Organização de médio porte, IA voltada ao cliente, várias unidades de negócio, dependências materiais de dados/modelos ou impacto moderado	Política/governança formal de IA, revisão multifuncional, gates do ciclo de vida, TEVV documentado, controles de fornecedores, métricas, revisão de mudanças e reporte periódico à gestão
Aprimorado	Empresa grande ou complexa, uso regulado/sensível à segurança/de alto impacto, autonomia ou escala substancial ou consequência severa	Governança executiva de risco, desafio independente, TEVV mais profundo, participação de partes afetadas, red teaming quando apropriado, monitoramento contínuo, forte autoridade de fallback/parada e aceitação documentada do risco residual

Escale acima do caminho padrão quando qualquer um destes fatores for material: crianças ou grupos vulneráveis; emprego, crédito, saúde, educação, segurança, aplicação da lei, serviços essenciais ou outras decisões consequenciais; ações autônomas; dados sensíveis ou em grande volume; opacidade de modelo/provedor; IA generativa ou agêntica com acesso a ferramentas; uso sensível à segurança; ampla exposição pública; obrigações legais ou contratuais significativas; incapacidade de reverter danos; ou evidência fraca de desempenho.

2. Construir um único ciclo operacional em torno de GOVERN, MAP, MEASURE e MANAGE

As funções do Core se reforçam mutuamente, não formando uma sequência executada apenas uma vez. A governança deve influenciar todas as demais funções, e novas evidências de medição ou operação devem atualizar o contexto e as decisões de gestão.

Manual 03 memory graphic 2

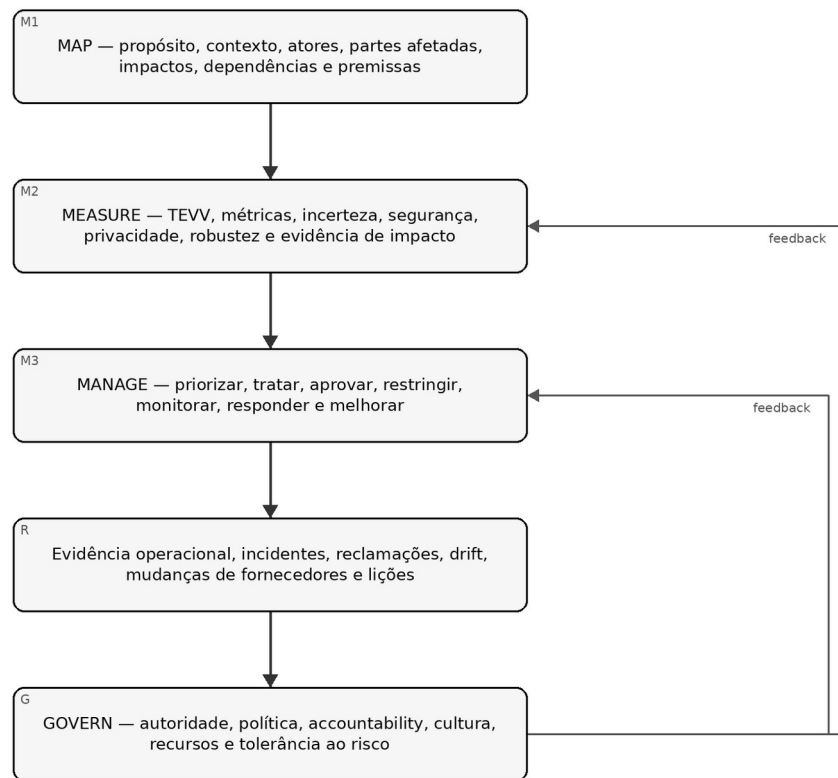


Figura 2. Gráfico de memória de implementação

Explicação acessível: GOVERN estabelece accountability e autoridade de decisão ao longo do ciclo de vida. MAP descreve o contexto real e os impactos potenciais. MEASURE produz evidências por meio de testes, avaliação, verificação, validação, métricas e outras análises. MANAGE usa essas evidências para priorizar e tratar riscos e tomar decisões operacionais. Evidências operacionais, incidentes, reclamações, drift e mudanças de fornecedores retornam à governança e levam a novo mapeamento e nova medição.

Ciclo operacional Essencial

1. Nomear o proprietário do negócio/sistema e o contato técnico responsável.
2. Registrar propósito, usuários, partes afetadas, dados, modelo/provedor, papel na decisão e usos proibidos.
3. Identificar benefícios plausíveis, danos, uso indevido, questões de segurança/privacidade, riscos de dependência e incerteza.
4. Testar o sistema contra um conjunto pequeno, porém relevante, de critérios de aceitação antes do uso aprovado.
5. Documentar a decisão: aprovar, aprovar com condições, piloto, restringir ou não usar.
6. Fornecer aos usuários instruções claras, expectativas de verificação, escalonamento e condições de parada.
7. Monitorar falhas-chave, reclamações, incidentes, mudanças de provedor/modelo e drift material.
8. Reavaliar após mudança material ou evidência de que as premissas estavam incorretas.

Ciclo operacional Estruturado

Adicionar ao caminho Essencial:

- governança multifuncional e propriedade do risco;
- critérios de risco e autoridades de decisão documentados;
- gates do ciclo de vida para intake, design/aquisição, avaliação, implantação, operação, mudança e retirada;
- plano TEVV documentado com dados representativos e limiares explícitos;
- controle de versão e linhagem de modelo/dados/provedor;

- verificações de privacidade, cibersegurança, acessibilidade, supervisão humana e partes afetadas quando relevantes;
- due diligence de fornecedores e requisitos contratuais/de evidência;
- processos formais de incidente/reclamação e ação corretiva;
- métricas gerenciais e revisão periódica; e
- retenção controlada de evidências.

Ciclo operacional Aprimorado

Adicionar ao caminho Estruturado:

- supervisão executiva ou do conselho para risco material de IA;
- validação/desafio independente proporcional à consequência;
- testes de cenário, estresse, adversariais, por subgrupos, uso indevido e modos de falha conforme aplicável;
- avaliação mais forte de fatores humanos e partes afetadas;
- controles explícitos de fallback, rollback, kill/stop, continuidade de negócios e alternativa manual;
- monitoramento contínuo ou quase contínuo dos principais riscos operacionais;
- aceitação formal de risco residual com prazo/condições de revisão;
- vigilância reforçada de fornecedor/subprocessador/mudança de modelo;
- exercícios para grandes incidentes de IA e comunicações; e
- análise em nível de portfólio de concentração, falha correlacionada e risco sistêmico.

3. Converter o Core em evidência, não em burocracia

Toda decisão material sobre risco de IA deve deixar uma cadeia rastreável do contexto à evidência e à ação.

Manual 03 memory graphic 3

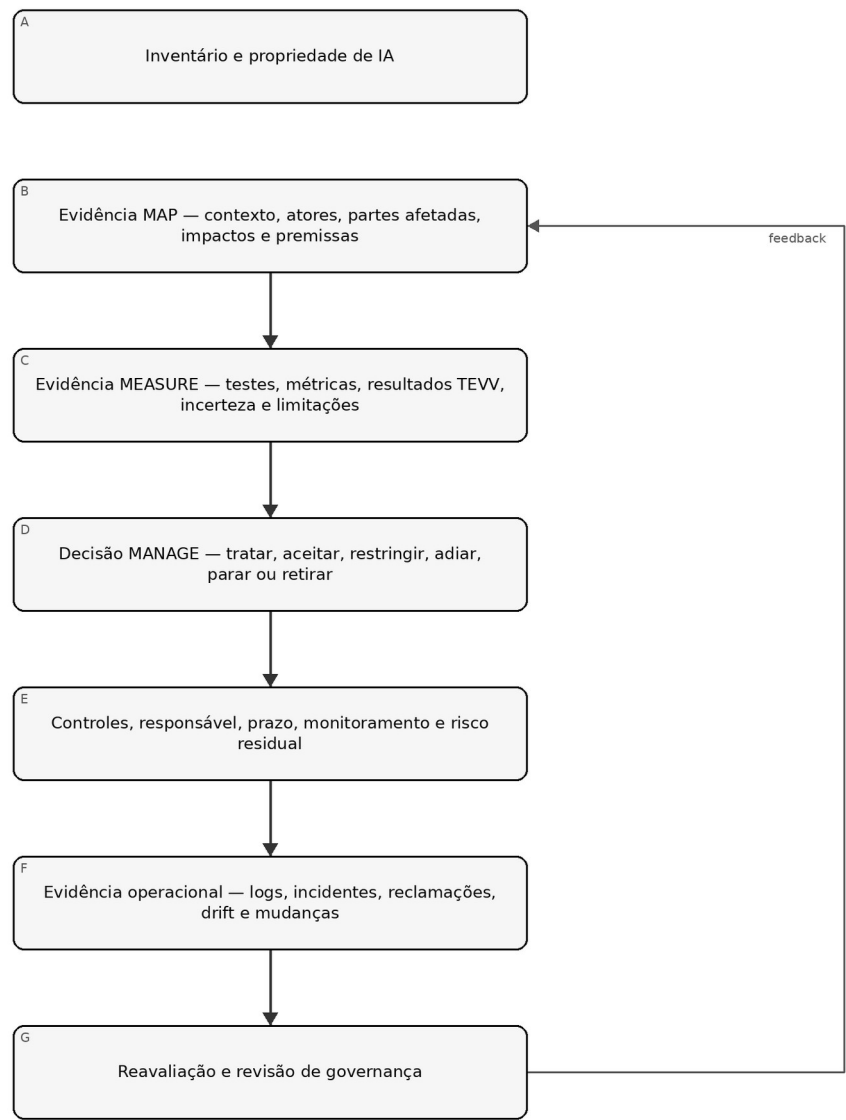


Figura 3. Gráfico de memória de implementação

Explicação acessível: A evidência começa com um inventário de IA com responsável definido, depois documenta contexto e impactos, testes e incerteza e a decisão de gestão resultante. Controles e risco residual são acompanhados durante a operação. Logs, incidentes, reclamações, drift e mudanças disparam reavaliação e revisão de governança. Uma política, por si só, não prova que o risco foi controlado.

Registro mínimo de evidência para um sistema material de IA:

Área de evidência	Registro mínimo
Identidade	Nome do sistema/uso, responsável, estágio do ciclo de vida, versão, provedor/modelo, processo de negócio e status
Contexto	Propósito, usuários, partes afetadas, geografia, escala, papel na decisão, dependências e premissas
Risco/impacto	Cenários, benefícios, danos, uso indevido, severidade, probabilidade quando significativa, incerteza e grupos afetados

Área de evidência	Registro mínimo
Medição	Método de avaliação, população/dados, versão, limiares, resultados, limitações, revisor e data
Tratamento	Controles, condições, restrições, supervisão humana, ações de fornecedores e remediação
Decisão	Aprovador autorizado, decisão de aprovar/restringir/pilotar/parar, risco residual, condições e expiração/gatilho de revisão
Operação	Medidas de monitoramento, reclamações, incidentes, drift, mudanças de provedor/modelo e evidência da operação do controle
Melhoria	Ação corretiva, reteste, lições aprendidas e atualizações de governança, contexto, medições ou tratamento

4. Aplicar NIST AI 600-1 quando IA generativa estiver no escopo

IA generativa não deve ser tratada como um sistema de governança completamente separado. Aplique o modelo operacional geral do AI RMF e depois acrescente análise e controles específicos de GenAI proporcionais ao uso.

No mínimo, avalie quando relevante:

- confabulação ou saída sem suporte;
- conteúdo prejudicial, ilegal, inseguro ou em violação de políticas;
- problemas de integridade e proveniência da informação;
- privacidade e exposição de dados sensíveis;
- propriedade intelectual e origem do conteúdo;
- prompt injection, abuso de ferramentas, data poisoning e outras ameaças de segurança;
- extração de modelo, abuso, agência excessiva e automação insegura;
- opacidade e risco de mudança de modelo fundacional/provedor de serviços de terceiros;
- confiança humana excessiva, automation bias e revisão inadequada;
- uso indevido em escala e facilitação de abuso;
- limitações de avaliação, contaminação de benchmark e baixa transferência de teste para produção; e
- monitoramento de prompts, saídas e traces com controles apropriados de privacidade e acesso.

Para GenAI agêntica ou que use ferramentas, adicione limites explícitos de autorização, menor privilégio, limites de transação, gates de confirmação, isolamento de ambiente, allowlists de ferramentas, bloqueios de ações de alto risco, logging, rollback e controles de parada de emergência.

5. Integrar com a governança existente em vez de duplicá-la

O Manual 03 deve reutilizar sistemas de evidência e decisão quando forem adequados ao propósito.

Capacidade existente	Integração com AI RMF
Gestão de riscos corporativos	Critérios de risco de IA, agregação, aceitação de risco residual e escalonamento
Programa de segurança / NIST CSF	Identidade, acesso, logging, vulnerabilidade, incidente, resiliência e cadeia de suprimentos
Programa de privacidade	Finalidade de dados, minimização, direitos, risco de privacidade, avisos, retenção e reclamações
Produto / SDLC	Requisitos, gates do ciclo de vida, testes, release, mudança e retirada
Governança de dados	Propriedade, qualidade, proveniência, acesso, retenção e linhagem
Risco de fornecedores	Due diligence de modelo/serviço, contratos, mudanças, incidentes, evidência e saída
Qualidade / segurança	Verificação, validação, análise de falhas, ação corretiva e melhoria contínua
Auditoria interna / assurance	Teste independente de governança, evidência, desenho e

Capacidade existente	Integração com AI RMF
	operação de controles
ISO/IEC 42001	Estrutura de sistema de gestão, operação documentada de controles, auditoria/revisão e melhoria
EU AI Act / legislação setorial	Aplicabilidade vinculante e obrigações legais mantidas separadas da orientação voluntária do NIST

Não afirme que implementar o AI RMF estabelece automaticamente conformidade com ISO/IEC 42001 ou conformidade legal. Crosswalks são ferramentas de reutilização de evidências, não afirmações de equivalência.

6. Definir gates de decisão e condições de parada

Toda organização deve definir quem pode tomar decisões materiais sobre IA e quando o uso deve ser pausado.

Resultados típicos de decisão:

- Aprovar: a evidência atende aos critérios atuais e o risco residual está dentro da autoridade.
- Aprovar com condições: uso limitado é permitido com restrições explícitas, monitoramento e expiração/revisão.
- Piloto: a incerteza é alta demais para uso amplo; aprova-se um experimento delimitado para gerar evidência.
- Remediar antes do uso: lacunas materiais de controle ou evidência devem ser encerradas primeiro.
- Restringir: reduz-se escopo, população, autonomia, dados ou funcionalidade.
- Parar/reverter: dano real ou plausível excede a tolerância, controles críticos falham ou operação segura não pode ser demonstrada.
- Retirar: o sistema é removido e dependências, dados, identidades, contratos e registros são tratados por uma saída controlada.

Exemplos de gatilhos automáticos de revisão/parada devem incluir incidentes severos; mudanças materiais de modelo/provedor; exposição não autorizada de dados; comprometimento de segurança; degradação material de desempenho ou de subgrupos; saídas prejudiciais repetidas; reclamações significativas; novas populações ou geografias afetadas; expansão para decisões consequenciais; perda da supervisão humana exigida; evidência de fornecedor expirada; ou nova obrigação vinculante que afete o uso.

7. Medir se a gestão de risco de IA está melhorando

As métricas devem responder perguntas gerenciais, não premiar volume de documentação.

Exemplos úteis incluem:

- percentual de usos ativos de IA reconciliados a um responsável e nível de risco atuais;
- tempo entre intake/mudança material e decisão de risco aprovada;
- percentual de sistemas materiais com evidência de avaliação atual vinculada à versão implantada;
- falhas de avaliação de alta severidade não resolvidas e sua idade;
- incidentes, reclamações, overrides, recursos e padrões repetidos de falha;
- medidas de drift/desempenho/segurança/privacidade vinculadas a limiares de ação;
- percentual de fornecedores críticos de IA com evidência atual e mudanças materiais revisadas;
- aprovações de risco residual ou exceções vencidas;
- ações corretivas retestadas quanto à efetividade dentro de metas baseadas em risco; e
- sistemas parados, restringidos ou redesenhados porque a evidência não sustentava o uso continuado.

Uma métrica é útil apenas quando a gestão sabe qual decisão ou ação ela deve acionar.

8. Manter a linha de base atual sem alterar silenciosamente o manual

Como o NIST anunciou uma revisão do AI RMF, o Manual 03 deve distinguir monitoramento de fonte de adoção de fonte.

Quando o NIST publicar uma nova versão do AI RMF:

9. congelar o candidato de release atual do Manual 03;
10. verificar a publicação final exata do NIST e seu estado efetivo de publicação;
11. comparar o novo framework com a linha de base controlada do AI RMF 1.0;
12. classificar mudanças como editoriais, terminologia, estruturais, de resultado/ação, implementação, crosswalk ou impactos de assurance;
13. identificar capítulos, templates, gráficos, traduções e controles de QA afetados;

14. atualizar primeiro a fonte controlada em inglês;
15. realizar revisão semântica humana das mudanças localizadas;
16. regenerar os artefatos de release; e
17. publicar um histórico de mudanças claro em vez de sobrescrever orientação anterior sem explicação.

Limite de assurance: A aprovação do gate do repositório do Manual 03 validará estrutura controlada, estado das fontes, acessibilidade e expectativas de evidência. Ela não certificará uma organização, determinará conformidade legal, garantirá IA confiável, eliminará risco nem constituirá uma opinião de auditoria.

Manual controlado de 32 capítulos

1. Propósito do NIST AI RMF, limite voluntário e modelo de implementação

O NIST AI RMF 1.0 é um framework voluntário e não setorial para gerenciar riscos de IA e apoiar práticas de IA confiáveis e responsáveis.

1.1 O que implementação significa

Implementação significa incorporar decisões de risco ao trabalho normal da organização. Uma implementação útil do AI RMF conecta:

- estratégia e tolerância ao risco;
- inventário e responsabilidade por IA;
- gates de produto, aquisição e ciclo de vida;
- análise de partes afetadas e stakeholders;
- avaliação técnica e não técnica;
- governança de dados, modelos, software, infraestrutura e fornecedores;
- cibersegurança, privacidade, safety, qualidade e resiliência;
- instruções aos usuários e supervisão humana;
- monitoramento, reclamações e resposta a incidentes;
- aceitação e escalonamento de risco residual; e
- ação corretiva, aprendizado e retirada.

1.2 O que implementação não significa

- Completar todas as sugestões do Playbook independentemente do contexto.
- Tratar todos os sistemas de IA como igualmente arriscados.
- Presumir que uma pontuação alta em benchmark prova desempenho aceitável no mundo real.
- Tratar uma declaração de fornecedor como evidência suficiente para o contexto do cliente.
- Tratar o uso do AI RMF como conformidade legal, certificação ISO/IEC 42001 ou opinião de auditoria.
- Afirmar que um sistema é “confiável” apenas porque existe um documento de governança.

1.3 Uma unidade prática de accountability

Use o registro de sistema/uso de IA como unidade mínima que conecta governança a operações. Um registro pode cobrir um serviço ou caso de uso estritamente controlado, mas não agregue usos não relacionados quando partes afetadas, consequências de decisão, modelos, dados, configurações, fornecedores ou proprietários de risco diferirem materialmente.

Campo	Conteúdo mínimo
Identidade	Nome do sistema/uso, ID único, responsável, processo de negócio e status do ciclo de vida
Propósito	Tarefa pretendida, papel na decisão/conteúdo, usuários e benefício esperado
Escopo	Geografia, população, escala, autonomia e usos proibidos
Tecnologia	Modelo/serviço, versão, software, ferramentas, infraestrutura e integrações
Dados	Entradas, saídas, dados sensíveis, fontes, retenção e linhagem principal
Partes	Atores de IA, usuários, pessoas/grupos afetados, fornecedores e revisores
Risco	Nível, cenários materiais, incerteza, tratamento e autoridade sobre risco residual
Evidência	Avaliação, aprovações, monitoramento, incidentes, reclamações

Campo	Conteúdo mínimo
	e mudanças

2. Arquitetura de gestão de riscos de IA e ciclo operacional de quatro funções

As funções Core devem se reforçar continuamente; elas não são quatro caixas preenchidas uma única vez.

Manual 03 memory graphic 4

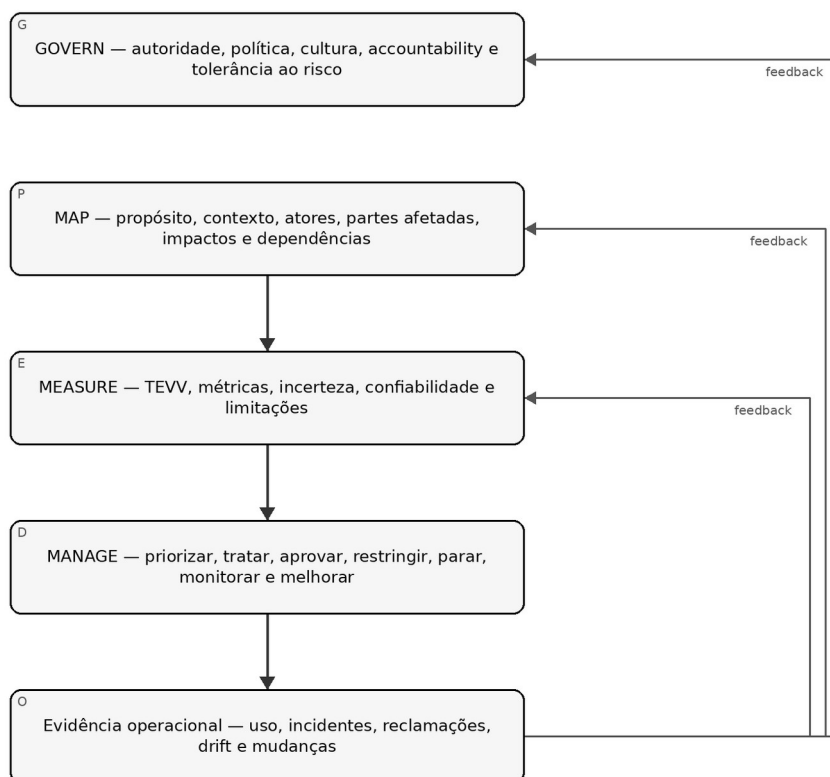


Figura 4. Gráfico de memória do capítulo

Explicação acessível: A governança estabelece quem pode decidir e como o risco é tratado. MAP descreve o contexto real e as pessoas ou sistemas afetados. MEASURE cria evidências por meio de testes e outras avaliações. MANAGE usa as evidências para tratar e aceitar ou rejeitar o risco. Resultados operacionais, incidentes, reclamações e mudanças retornam às quatro funções.

2.1 A governança é transversal

Não isole GOVERN como uma atividade anual de comitê. A governança deve determinar:

- quem é responsável por cada uso de IA;
- quando especialistas jurídicos, de privacidade, segurança, safety, acessibilidade ou domínio devem participar;
- qual nível de esforço de gestão de riscos é necessário;
- quem pode aprovar o risco residual;
- quais evidências são necessárias antes da implantação;
- quais eventos exigem reavaliação; e
- quando um sistema deve ser restringido, revertido ou retirado.

2.2 Perfis e adaptação

Uma implementação prática pode criar um perfil para um caso de uso, unidade de negócio ou setor. A adaptação deve identificar:

- quais resultados do AI RMF importam mais no contexto;
- estado atual e estado-alvo desejado;
- tolerância ao risco e restrições legais/contratuais;
- evidências e métricas;
- expectativas de recursos e independência; e
- ações planejadas com responsáveis e datas.

A adaptação não deve ser usada para ocultar riscos conhecidos de alta consequência ou remover uma obrigação vinculante.

3. Inventário de IA, atores, responsabilidade e limites do ciclo de vida

Uma organização não pode governar IA que não consegue identificar, classificar e atribuir a pessoas responsáveis.

Manual 03 memory graphic 5

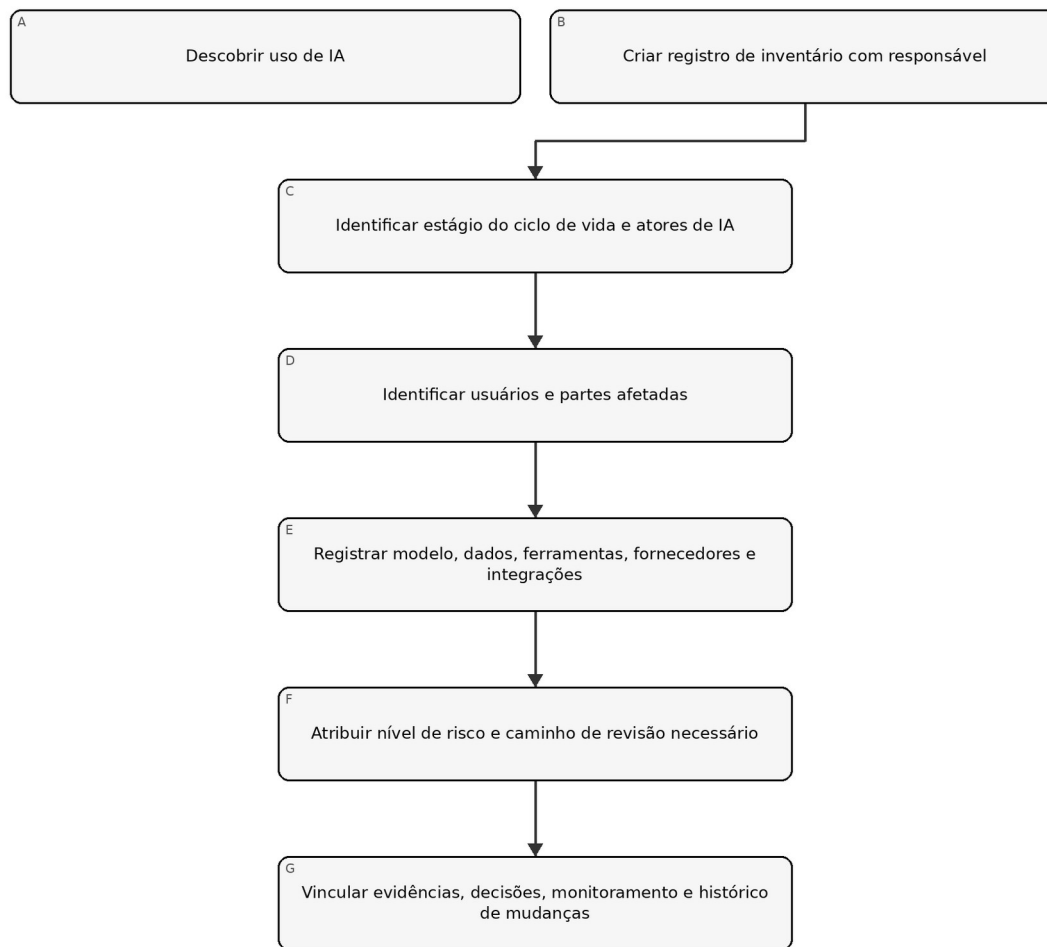


Figura 5. Gráfico de memória do capítulo

Explicação acessível: A descoberta cria um registro de inventário. Em seguida, a organização identifica quem desenvolve, fornece, opera, usa, supervisiona e é afetado pela IA; registra dependências técnicas e de fornecedores; atribui um caminho de revisão proporcional; e vincula evidências e decisões ao longo do ciclo de vida.

3.1 Fontes de descoberta

Reconcilie várias fontes porque o autorrelato sozinho não encontra toda a shadow AI:

- registros de compras e despesas;
- inventários de nuvem e SaaS;
- uso e faturamento de modelos/API;
- repositórios de software e dependências de pacotes;
- logs de identidade e acesso;
- inventários de extensões de endpoint/navegador;
- catálogos de dados e plataformas de integração;
- arquitetura de produtos e catálogos de serviços;
- registros de risco de fornecedores;
- entrevistas e atestações de empregados; e
- monitoramento de segurança quando apropriado e legal.

3.2 Atores de IA

Documente os papéis pela atividade real, não pelo cargo. Atividades comuns incluem:

- governança executiva e de riscos;
- comissionamento do sistema e responsabilidade pelo produto;
- aquisição, preparação e stewardship de dados;
- desenvolvimento, adaptação ou configuração de modelos;
- engenharia de software e infraestrutura;
- teste, avaliação, verificação e validação;
- implantação e operações;
- supervisão humana e revisão de decisões;
- suporte ao usuário, reclamações e reparação;
- revisão de segurança, privacidade, jurídico, compliance e safety;
- gestão de fornecedores e contratos; e
- assurance/auditoria independente.

Uma pessoa pode executar vários papéis em uma organização pequena, mas conflitos de interesse devem ser identificados e revisões compensatórias devem ser adicionadas para riscos materiais.

3.3 Partes afetadas

Pessoas afetadas podem nunca usar o sistema. Considere pessoas cujo emprego, acesso, elegibilidade, segurança, reputação, finanças, privacidade, expressão, aprendizado, saúde, mobilidade ou outros interesses possam ser influenciados pelo processo habilitado por IA.

Registre:

- usuários diretos;
- sujeitos de decisões;
- pessoas representadas nos dados;
- observadores e grupos indiretamente afetados;
- clientes ou trabalhadores downstream;
- comunidades ou populações afetadas em escala; e
- organizações ou sistemas públicos que dependam das saídas.

4. Roteamento proporcional por risco e complexidade

A intensidade de recursos deve seguir consequências plausíveis, incerteza e complexidade, e não apenas o tamanho da organização.

Manual 03 memory graphic 6

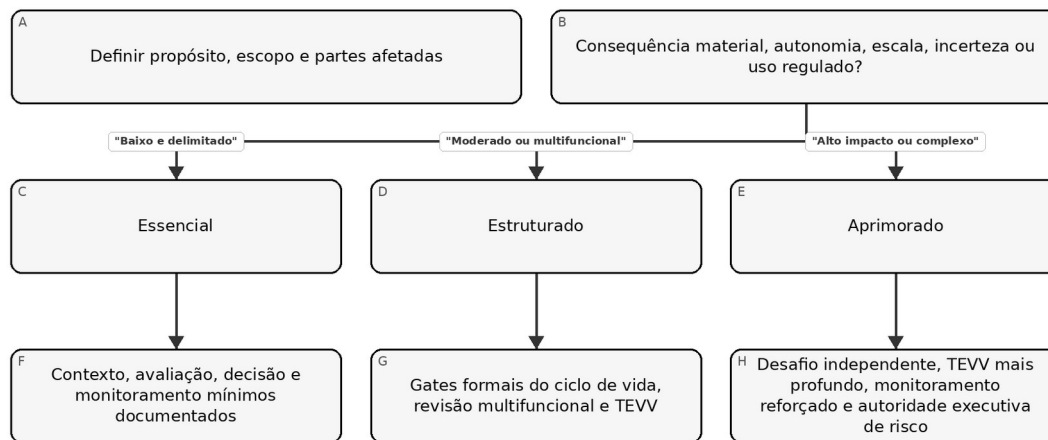


Figura 6. Gráfico de memória do capítulo

Explicação acessível: A organização começa pelo contexto e pelas partes afetadas, depois considera consequências potenciais, autonomia, escala, incerteza e exposição regulatória. Usos de baixo risco e escopo limitado podem usar o caminho Essencial. Usos moderados exigem o caminho Estruturado. Usos de alto impacto ou complexos exigem o caminho Aprimorado, com maior independência e supervisão.

4.1 Fatores de risco

Considere pelo menos:

- severidade e reversibilidade do dano plausível;
- número e vulnerabilidade das pessoas afetadas;
- se o uso influencia decisões consequenciais;
- grau de automação ou autoridade de ação;
- exposição pública e potencial de abuso;
- sensibilidade e volume de dados;
- opacidade do modelo e controle do fornecedor;
- novidade e incerteza;
- consequências de cibersegurança e safety;
- complexidade geográfica/jurídica;
- capacidade de monitorar e corrigir resultados; e
- risco de concentração ou dependência de modo comum.

4.2 Registro de nível

Campo	Exemplo de evidência
Consequência inerente	Narrativa mais dimensões como safety, direitos, finanças, segurança ou operações
Probabilidade/incerteza	Dados, julgamento de especialistas, incidentes análogos, premissas e confiança
Exposição	Escala, frequência, duração, população e geografia
Autonomia	Consultivo, aprovado por humano, executado automaticamente ou agêntico/com ferramentas
Força do controle	Controles existentes e limitações conhecidas
Nível/caminho	Essencial, Estruturado ou Aprimorado com justificativa

Campo	Exemplo de evidência
Autoridade	Pessoa/comitê autorizado a aprovar o nível e o risco residual
Gatilho de revisão	Mudança, incidente, reclamação, drift, atualização legal/do fornecedor ou revisão programada

5. Arquitetura da função GOVERN

GOVERN torna durável a gestão de riscos de IA ao estabelecer política, accountability, cultura, engajamento, controles de fornecedores e mecanismos de revisão.

A função GOVERN atual do AI RMF 1.0 agrupa resultados em seis temas amplos. Para implementação, trate-os como:

18. infraestrutura organizacional de política/processo e tolerância ao risco;
19. accountability, treinamento e autoridade de decisão;
20. capacidade interdisciplinar e papéis de supervisão humano-IA;
21. cultura consciente de risco, documentação de impacto, testes e compartilhamento de informações;
22. engajamento externo e interno com feedback significativo; e
23. governança de terceiros e cadeia de suprimentos, incluindo planejamento de contingência.

Cautela de revisão: O NIST identificou especificamente que parte da terminologia atual do AI RMF 1.0 está sujeita a revisão. Preserve rastreabilidade no nível de identificadores à linha de base controlada 1.0, mas não apresente a redação atual das categorias como texto futuro imutável.

5.1 Hierarquia de evidências de governança

Evidências mais fortes avançam da intenção para a operação:

- Intenção: política, charter, princípios e tolerância ao risco.
- Desenho: processo definido, papéis, direitos de decisão, templates e controles.
- Operação: revisões, aprovações, testes, ações de fornecedores e registros de incidentes concluídos.
- Efetividade: evidência de que controles alteram decisões, reduzem risco ou detectam falhas.
- Melhoria: causas corrigidas, políticas/processos atualizados e acompanhamento verificado.

6. GOVERN: política, obrigações legais, tolerância ao risco e inventário

Políticas devem conectar prioridades de risco de IA a decisões repetíveis em vez de apenas repetir princípios amplos.

6.1 Política de IA

Uma política prática deve definir:

- propósito e escopo;
- limites de uso aprovado/proibido;
- accountability e escalonamento;
- método de classificação por risco;
- gatilhos de revisão legal/regulatória/contratual;
- requisitos de dados e segurança;
- expectativas mínimas de avaliação;
- expectativas de supervisão humana;
- controles de fornecedores;
- deveres de monitoramento e incidentes;
- manutenção de registros; e
- exceções e aplicação interna.

6.2 Registro de obrigações

O AI RMF é voluntário, mas sistemas de IA podem estar sujeitos a obrigações vinculantes. Mantenha um registro separado de obrigações com:

Campo	Conteúdo mínimo
Fonte	Lei, regulamento, contrato, política, padrão ou requisito do cliente
Jurisdição	País/estado/setor/relação comercial
Aplicabilidade	Sistema/uso/dados/parte/processo afetado
Requisito	Obrigaç�o pr�tica expressa em linguagem organizacional
Respons�vel	Funç�o/pessoa accountable
Evid�ncia	Controle, registro, teste ou aprovaç�o
Monitoramento de mudan�a	Monitor de fonte e frequ�ncia de revis�o

N o rotule uma sugest o volunt ria do NIST como lei. N o declare conformidade legal apenas porque existe um mapeamento para um resultado do AI RMF.

6.3 Toler ncia ao risco e esfor o

Defina quais decis es podem ser tomadas em cada n vel. Por exemplo:

- aprova  o pelo respons vel para baixo risco dentro de cr terios documentados;
- revis o multifuncional para risco moderado;
- aprova  o executiva/de comit  para alto risco;
- escalonamento obrigat rio para uso proibido ou legalmente restrito;
- desafio independente para sistemas de alta consequ ncia; e
- autoridade de parada quando controles cr ticos falharem.

O esfor o de gest o de riscos deve ser dimensionado de acordo com a prioridade do risco.

6.4 Invent rio como controle de governan a

O invent rio deve ser reconciliado periodicamente e ap s aquisi  o, implanta  o ou mudan a material. Um invent rio desatualizado   uma falha de governan a porque processos de risco posteriores dependem de uma popula  o completa.

7. GOVERN: accountability, compet ncia, supervis o humana e desafio efetivo

A responsabilidade deve ser expl cita o suficiente para que uma decis o material de IA possa ser rastreada at  pessoas com autoridade e compet ncia.

7.1 Modelo de responsabilidades

No m nimo, identifique:

- patrocinador executivo;
- respons vel pelo neg cio/sistema;
- respons vel t cnico/modelo;
- propriet rio/steward de dados;
- revisores de risco/compliance/jur dico/privacidade/seguran a/safety conforme aplic vel;
- papel de supervis o humana;
- respons vel por fornecedor;
- respons vel por incidente;
- aprovador de risco residual; e
- papel de assurance independente quando necess rio.

7.2 Compet ncia

A compet ncia depende do papel. A evid ncia pode incluir educa  o, experi ncia, pr tica supervisionada, treinamento, avalia  o e produtos de trabalho revisados. A avalia  o de alto risco requer compet ncia tanto na tecnologia quanto no dom nio onde as consequ ncias ocorrem.

O treinamento deve cobrir decisões reais que as pessoas tomam, como:

- reconhecer uso de IA não aprovado;
- tratar dados restritos;
- interpretar confiança e limitações do modelo;
- verificar saídas;
- reconhecer automation bias;
- escalar preocupações de safety/segurança/privacidade;
- responder a incidentes; e
- usar procedimentos de parada ou fallback.

7.3 Supervisão humana

“Human in the loop” não é suficiente por si só. Documente:

- o que o humano vê;
- o que se espera que ele verifique;
- tempo e informações disponíveis;
- autoridade para discordar ou parar;
- incentivos e carga de trabalho;
- competência;
- logging de overrides; e
- evidência de que a intervenção é efetiva.

Um revisor que aceita automaticamente a saída de IA não é um controle significativo.

7.4 Desafio efetivo

Para riscos materiais, use um revisor ou grupo capaz de questionar premissas e com autoridade, independência, experiência e acesso a evidências suficientes para afetar a decisão. A independência pode ser dimensionada em organizações pequenas por revisão por pares, expertise externa ou separação entre aprovação e criação.

8. GOVERN: cultura, engajamento, fornecedores e resiliência de terceiros

A gestão de riscos de IA depende da disposição da organização para expor falhas, ouvir perspectivas afetadas e controlar dependências que não possui.

8.1 Cultura consciente de risco

Práticas úteis incluem:

- liderança que recompense o escalonamento de preocupações materiais;
- canais protegidos de reporte;
- pre-mortems e revisão de modos de falha;
- discordância documentada em decisões de alto risco;
- red teaming ou desafio adversarial quando apropriado;
- aprendizado com incidentes e quase incidentes; e
- evitar incentivos de entrega que punam atraso seguro ou decisões de parada.

8.2 Engajamento e feedback

O engajamento deve ser proporcional e significativo, não performático. Defina:

- por que o feedback é buscado;
- quais perspectivas afetadas ou especializadas são necessárias;
- como participantes são selecionados e protegidos;
- necessidades de acessibilidade e idioma;
- como o feedback é registrado e adjudicado;
- o que mudou por causa do feedback; e
- como preocupações não resolvidas são escaladas.

O feedback pode vir de usuários, pessoas afetadas, trabalhadores, especialistas de domínio, suporte ao cliente, reclamações, processos de recurso, bancos de dados de incidentes, reguladores, pesquisadores ou organizações da sociedade civil, conforme o contexto.

8.3 Governança de fornecedores e terceiros

Cadeias de suprimentos de IA podem incluir foundation models, APIs, datasets, componentes open source, ferramentas de avaliação, infraestrutura de nuvem, serviços humanos de rotulagem, filtros de safety e plataformas de orquestração.

A evidência mínima de fornecedor deve abordar:

- produto/modelo/serviço e versão exatos;
- uso pretendido e restrições contratuais;
- tratamento de dados, retenção e uso para treinamento;
- evidência de segurança e privacidade;
- evidência de desempenho/avaliação e limitações;
- práticas de notificação de mudanças;
- subprocessadores/dependências;
- notificação de incidentes/vulnerabilidades;
- continuidade, portabilidade e saída; e
- alocação de responsabilidades entre fornecedor e cliente.

8.4 Planejamento para falha de terceiros

Para dependências materiais, planeje para:

- indisponibilidade do modelo/serviço;
- degradação material de qualidade;
- atualização silenciosa do modelo;
- incidente de segurança do fornecedor;
- perda de API/funcionalidade;
- alteração de termos ou práticas de dados;
- saída do fornecedor ou descontinuação do serviço; e
- incapacidade de obter evidência necessária para continuar aceitando o risco.

O fallback pode incluir fornecedores alternativos, modo degradado seguro, processo manual, limitação de tráfego, resultados aprovados em cache, desativação de funcionalidades ou parada completa, dependendo do uso.

Checkpoint da Parte 1: Os capítulos 1–8 estabelecem consciência de versão, inventário, roteamento proporcional e a base de governança. A Parte 2 continua com MAP e análise do contexto afetado.

9. Arquitetura da função MAP e registro de contexto

MAP estabelece contexto sociotécnico suficiente para identificar riscos, benefícios, partes afetadas e necessidades de medição relevantes.

Mapeamento não é um questionário executado uma única vez. É uma descrição controlada do sistema conforme sua intenção, configuração, fornecimento e uso real. O registro deve ser específico o bastante para que revisores distingam diferentes implantações, populações, versões de modelo ou papéis de decisão.

Manual 03 memory graphic 7

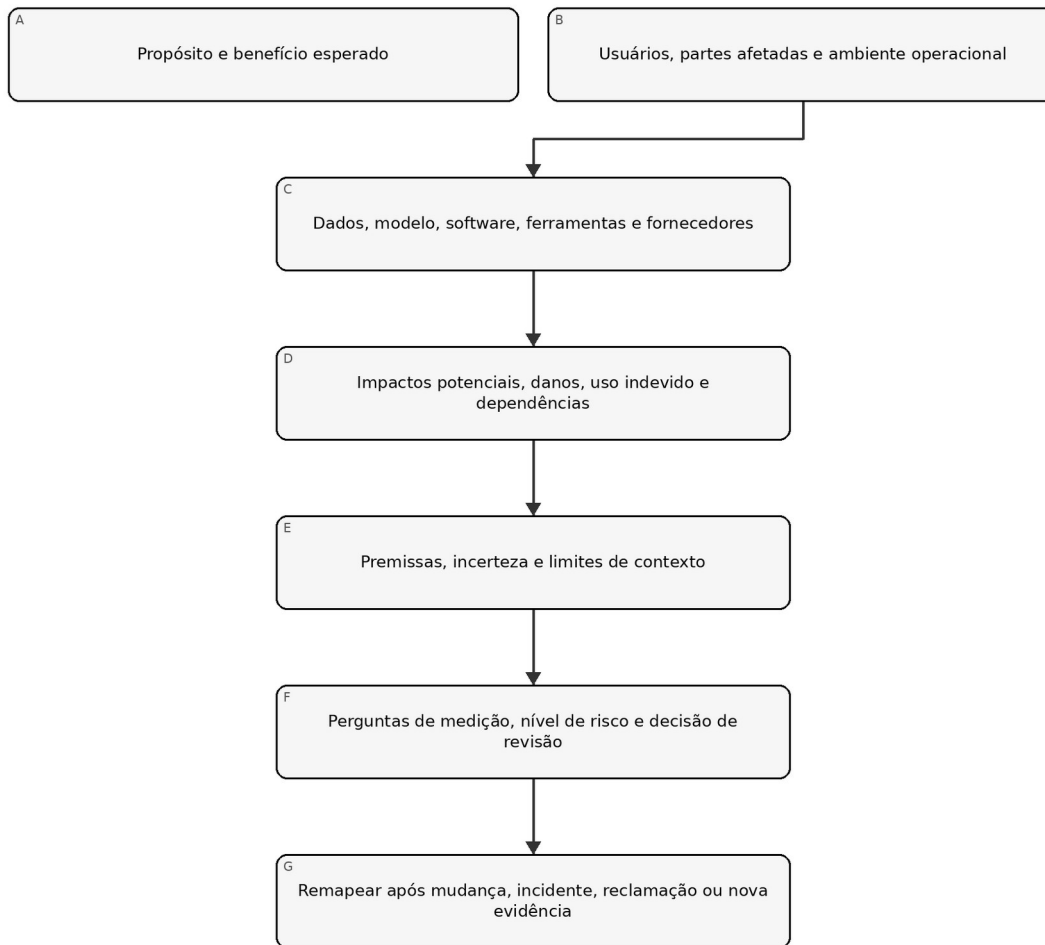


Figura 7. Gráfico de memória do capítulo

Explicação acessível: O mapeamento começa pelo propósito e benefício esperado, depois documenta usuários e partes afetadas, dependências técnicas e de fornecedores, impactos plausíveis e uso indevido e principais premissas. Esses fatos determinam perguntas de medição e nível de risco. Mudanças, incidentes, reclamações e novas evidências levam o sistema de volta ao mapeamento.

9.1 Registro de contexto

Mantenha um registro controlado de contexto para cada sistema ou uso de IA materialmente distinto. Ele deve estar vinculado ao registro de inventário e incluir:

- propósito de negócio e benefício esperado;
- limite do sistema e estágio do ciclo de vida;
- atores de IA, responsável accountable e autoridade de decisão;
- usuários diretos, sujeitos de decisão e partes indiretamente afetadas;
- ambiente operacional, geografia, frequência, escala e duração;
- papel na decisão ou no conteúdo e grau de autonomia;
- dependências de dados, modelos, software, ferramentas e infraestrutura;
- terceiros e limites contratuais;
- impactos positivos e negativos plausíveis;
- cenários razoáveis de uso indevido e falha;

- premissas, incertezas e lacunas de evidência;
- requisitos aplicáveis e expectativas de stakeholders;
- nível inicial de risco e justificativa; e
- perguntas de medição, limiares e gatilhos de revisão.

9.2 Critérios de qualidade do contexto

Um registro de contexto está pronto para revisão quando é:

- específico: identifica uso, população, versão e ambiente reais;
- rastreável: vincula afirmações a evidências, responsáveis e datas;
- delimitado: declara o que está excluído e por quê;
- plural: considera perspectivas técnicas, humanas, organizacionais e sociais quando relevantes;
- questionável: registra premissas e discordâncias em vez de apresentar certeza inexistente;
- atual: reflete a configuração implantada ou proposta; e
- acionável: produz perguntas mensuráveis e escolhas gerenciais.

Descrições genéricas de produto, marketing de fornecedor, slogans de política e resumos de benchmark não atendem a esse padrão por si só.

10. Propósito pretendido, escopo, atores e contexto do ciclo de vida

O risco não pode ser avaliado sem definir o que se espera que a IA faça, onde é usada e como as pessoas interagem com ela.

10.1 Declaração de propósito pretendido

Escreva o propósito em linguagem operacional:

O sistema auxilia [usuários identificados] com [tarefa ou decisão específica] para [população/ambiente definido] ao produzir [saída/ação]. Espera-se que forneça [benefício mensurável]. Não deve ser usado para [usos proibidos ou não validados].

Evite propósitos como “melhorar eficiência” a menos que o registro defina processo, usuário, saída, consequência e métrica.

10.2 Escopo e limites

Registre:

- unidades organizacionais e processos;
- jurisdições e idiomas;
- populações usuárias e afetadas;
- canais, dispositivos e ambientes;
- horários de operação e volume esperado de transações;
- integrações e decisões downstream;
- caráter consultivo versus ação automática;
- pontos de revisão humana;
- versões de dados e modelos;
- status de piloto, produção ou retirada; e
- usos e ambientes excluídos.

Se um mesmo modelo apoiar decisões, populações ou níveis de autonomia diferentes, crie registros de uso vinculados em vez de ocultar variação de risco em uma única entrada ampla de inventário.

10.3 Contexto do ciclo de vida

Identifique os estágios atuais e planejados:

24. conceito e intake;
25. design ou aquisição;
26. preparação de dados e desenvolvimento/configuração do modelo;

27. integração e avaliação pré-implantação;
28. piloto ou liberação limitada;
29. uso em produção;
30. monitoramento e mudança;
31. suspensão, rollback ou remediação; e
32. retirada e descarte controlado.

Diferentes evidências ficam disponíveis em diferentes estágios. O mapeamento inicial depende mais de premissas, evidência análoga e salvaguardas planejadas. O mapeamento em produção deve incorporar desempenho observado, incidentes, reclamações, overrides, drift e mudanças de fornecedores.

10.4 Mapeamento ator-tarefa

Mapeie pessoas e organizações para tarefas reais, autoridade e evidências. Inclua fornecedores externos quando desenvolverem, configurarem, avaliarem, hospedarem ou monitorarem parte do sistema.

Ator/tarefa	Atividade accountable	Evidência necessária
Responsável de negócio	Define propósito, benefício, processo e risco residual aceitável	Business case, declaração de propósito, aprovações
Responsável de produto/sistema	Mantém o registro do ciclo de vida e coordena gates	Inventário, contexto, log de decisões, histórico de mudanças
Papéis de dados/modelo/engenharia	Constroem, configuram e operam componentes técnicos	Linhagem, registros de versão, design e evidências de teste
Especialista de domínio	Testa se o sistema funciona de forma segura no domínio real	Revisão de cenários, critérios de aceitação, limitações
Usuário de supervisão	Verifica ou desafia saídas em operação	Instruções, competência, evidências de override e escalonamento
Revisores de risco/jurídico/privacidade/segurança/safety	Aplicam requisitos especializados e challenge de risco	Findings, decisões, condições e remediação
Responsável por fornecedor	Controla evidência do fornecedor, contratos e mudanças	Due diligence, cláusulas, notificações e plano de saída
Revisor de assurance	Testa de forma independente design ou operação quando necessário	Escopo, workpapers, findings e conclusão

11. Partes afetadas, benefícios, impactos e danos

A unidade relevante de análise não é apenas o usuário ou cliente; inclui pessoas, grupos, organizações e sistemas influenciados pelo processo habilitado por IA.

11.1 Mapa de partes afetadas

Manual 03 memory graphic 8

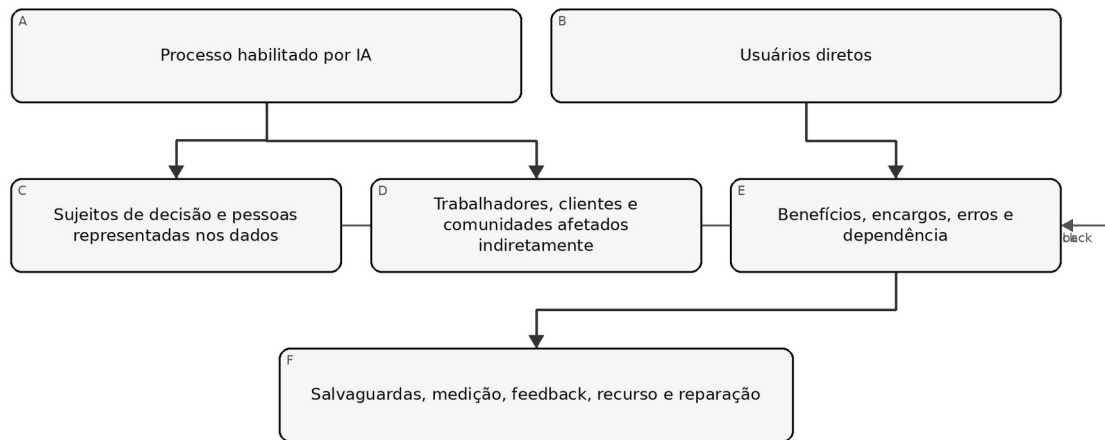


Figura 8. Gráfico de memória do capítulo

Explicação acessível: Um processo habilitado por IA pode afetar usuários diretos, pessoas que são objeto de decisões ou representadas nos dados e pessoas ou comunidades afetadas indiretamente. O mapeamento considera benefícios, encargos, erros e dependência para cada grupo e então determina salvaguardas, avaliação, feedback, recurso e necessidades de reparação.

11.2 Análise de benefícios

Expresse benefícios esperados como afirmações testáveis. Considere:

- melhoria de acesso, qualidade, tempestividade ou consistência;
- redução de trabalho perigoso ou repetitivo;
- melhor detecção ou suporte à decisão;
- personalização ou acessibilidade;
- eficiência de custos ou recursos; e
- novas capacidades científicas, educacionais, criativas ou operacionais.

Para cada benefício material, registre beneficiário, métrica, baseline, evidência e possível tradeoff. Uma economia projetada para a organização não prova automaticamente benefício para pessoas afetadas.

11.3 Cenários de impacto e dano

Use declarações que conectem causa, evento e consequência:

Devido a [condição ou fraqueza], o sistema pode [erro, uso indevido ou falha] durante [contexto], causando [consequência] a [parte afetada]. A detecção pode ser difícil por causa de [limitação].

Considere:

- segurança física ou psicológica;
- direitos civis, acesso, elegibilidade e devido processo;
- consequências em emprego, educação, moradia, crédito, seguros ou saúde;
- privacidade, vigilância e autonomia;
- perda econômica, fraude e manipulação;
- comprometimento de segurança e interrupção operacional;
- reputação, dignidade, expressão e integridade da informação;
- efeitos ambientais ou comunitários quando materiais;
- exclusão por design inacessível ou idioma; e

- efeitos compostos ou cumulativos entre sistemas.

11.4 Severidade, exposição e reversibilidade

Não comprima todas as dimensões em uma única pontuação sem preservar a narrativa. Registre:

- severidade da consequência plausível;
- frequência e duração da exposição;
- número e vulnerabilidade das pessoas afetadas;
- reversibilidade e disponibilidade de reparação;
- detectabilidade antes do dano;
- concentração e potencial de falha correlacionada;
- probabilidade quando evidências suportarem uma estimativa significativa; e
- incerteza e confiança.

11.5 Feedback e representação

Para impactos materiais, determine qual perspectiva está faltando. Métodos podem incluir entrevistas, pesquisa com usuários, revisão de acessibilidade, consulta a trabalhadores, análise de reclamações, painéis de domínio, expertise de interesse público, engajamento comunitário ou testes controlados com participantes representativos.

Documente como o feedback alterou contexto, design, avaliação, restrições ou decisão. Se o feedback não puder ser obtido, registre a limitação e medidas compensatórias.

12. Dependências de dados, modelos, software, infraestrutura e fornecedores

O risco de IA emerge do sistema completo e da cadeia de suprimentos, não apenas do modelo.

12.1 Mapa de dependências

Documente a cadeia implantada desde a fonte de entrada até a saída/ação:

- coleta e validação de entradas;
- data stores, retrieval e transformações;
- modelo/provedor e versão ou endpoint exato;
- prompts, instruções de sistema, fine-tuning ou adapters;
- filtros de safety, policy engines e guardrails;
- orquestração, agents, ferramentas e permissões;
- software de aplicação e interface de usuário;
- controles de identidade, acesso, secrets e rede;
- serviços de logging, monitoramento e avaliação;
- revisão humana e sistemas downstream; e
- dependências de fallback, rollback e retirada.

12.2 Contexto de dados

Para cada dataset ou fluxo material de dados, registre:

- fonte, autoridade e propósito de coleta;
- população e período representados;
- métodos de seleção, rotulagem e transformação;
- qualidade, completude e lacunas conhecidas;
- dados sensíveis ou regulados;
- acesso, compartilhamento, retenção e exclusão;
- proveniência e versão;
- representatividade para o contexto pretendido;
- risco de contaminação, poisoning ou leakage; e
- restrições a treinamento, avaliação ou uso secundário.

12.3 Contexto de modelo e serviço

Registre o que a organização sabe e não sabe sobre:

- família do modelo, versão e comportamento de mudança;
- informações disponíveis sobre treinamento ou adaptação;
- uso pretendido e restrito;
- capacidades e limitações avaliadas;
- evidências de segurança, privacidade e safety;
- hosting regional e práticas de dados;
- restrições de disponibilidade, rate, latência e capacidade;
- subcontratados e ferramentas externas;
- notificação de atualização e opções de rollback; e
- portabilidade e saída.

A opacidade do fornecedor é um fator de risco, não prova de segurança ou insegurança. O cliente deve decidir se a evidência disponível é suficiente para seu próprio uso e consequências.

12.4 Concentração e risco de modo comum

Identifique se muitos processos dependem do mesmo modelo, dataset, nuvem, fornecedor, método de avaliação ou controle de safety. Uma única atualização ou indisponibilidade de fornecedor pode criar falha correlacionada em aplicações que de outro modo seriam separadas.

Para concentração material, defina limites, capacidade alternativa, operação degradada, fallback manual, comunicação e escalonamento executivo.

13. Cenários de uso indevido, abuso, segurança, privacidade, safety e resiliência

MAP inclui uso razoavelmente previsível e interação do sistema, não apenas operação pretendida.

13.1 Famílias de cenários

Considere, conforme relevante:

- uso não autorizado ou proibido;
- automação além da autoridade aprovada;
- prompt injection, abuso de ferramentas ou permissões excessivas;
- entrada maliciosa, data poisoning ou evasão;
- extração de modelo, privacy leakage ou saída sensível;
- integração insegura, exposição de secrets ou comprometimento de dependências;
- conteúdo prejudicial, enganoso, ilegal ou inseguro;
- excesso de confiança, automation bias e perda de habilidade humana;
- saída incorreta, fabricada ou inadequada ao contexto;
- falha por subgrupo ou acessibilidade;
- denial of service, exaustão de capacidade ou indisponibilidade de fornecedor;
- falha de monitoramento/logging;
- falha de rollback ou parada; e
- abuso em escala ou uso indevido coordenado.

13.2 Workpaper de misuse case

Campo	Pergunta
Ator	Quem poderia usar indevidamente a capacidade, intencional ou acidentalmente?
Acesso	Qual acesso a identidade, dados, prompt, ferramenta ou integração está disponível?
Caminho	Como controles normais poderiam ser contornados ou manipulados?

Campo	Pergunta
Consequência	O que poderia acontecer a pessoas, sistemas ou à organização?
Evidência	Quais incidentes, testes, threat intelligence ou casos análogos apoiam o cenário?
Prevenção	Quais controles de autorização, design ou processo reduzem a oportunidade?
Deteção	Qual sinal identifica tentativa ou uso indevido bem-sucedido?
Resposta	Quem pode conter, revogar, fazer rollback, notificar e recuperar?
Risco residual	O que permanece e quem pode aceitá-lo?

13.3 IA agêntica e com uso de ferramentas

Quando a IA puder chamar ferramentas ou executar transações, mapeie:

- ferramentas permitidas e bloqueadas;
- limites de identidade e credenciais;
- permissões de leitura, escrita, aprovação e execução;
- limites de transação, tempo e recursos;
- requisitos de confirmação;
- isolamento de ambiente;
- memória e contexto retido;
- trust boundaries de entrada/saída;
- monitoramento e traces completos de ações;
- revisão humana compensatória; e
- parada de emergência e revogação determinísticas.

14. Premissas, incerteza, validade de contexto e gatilhos de mudança

Um registro de risco que oculta incerteza cria falsa confiança e enfraquece decisões posteriores.

14.1 Registro de premissas

Para cada premissa material, registre:

- declaração;
- responsável;
- base ou evidência;
- confiança;
- consequência se falsa;
- método de validação e prazo;
- controles vinculados; e
- evento que a invalida.

Exemplos incluem competência esperada do usuário, comportamento estável do fornecedor, dados de avaliação representativos, tempo adequado para revisão humana, logging confiável ou escala limitada de implantação.

14.2 Tipos de incerteza

Distinga incerteza causada por:

- evidência insuficiente ou de baixa qualidade;
- populações ou ambientes em mudança;
- não determinismo do modelo;
- opacidade do fornecedor;
- modos de falha raros ou emergentes;
- limitações de medição;
- desacordo entre especialistas ou partes afetadas;

- comportamento adversarial desconhecido; e
- interpretação jurídica ou contratual incompleta.

A incerteza deve afetar profundidade de avaliação, limites de implantação, monitoramento, fallback e autoridade sobre risco residual.

14.3 Declaração de validade do contexto

Todo resultado material de avaliação deve declarar o contexto no qual se acredita aplicável. No mínimo, vincule o resultado a:

- modelo/serviço e versão;
- prompts, configuração e ferramentas;
- dados/população e período;
- ambiente e workflow;
- usuário e modelo de supervisão;
- condições medidas; e
- exclusões conhecidas.

14.4 Gatilhos de mudança

Manual 03 memory graphic 9

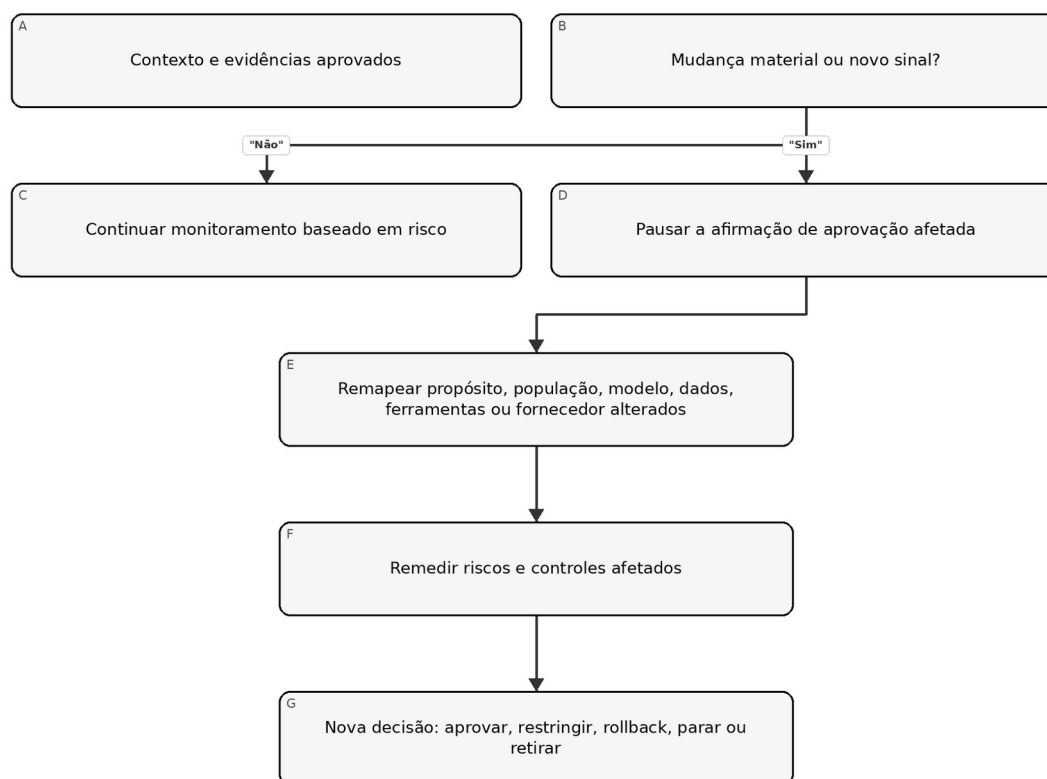


Figura 9. Gráfico de memória do capítulo

Explicação acessível: Um sistema aprovado permanece sob monitoramento. Uma mudança material ou novo sinal pausa a confiança na evidência de aprovação afetada. A organização remapeia o que mudou, reavalia riscos e controles afetados e registra uma nova decisão gerencial.

Dispare reavaliação após mudanças de propósito, população, geografia, modelo, dados, prompts, ferramentas, autonomia, fornecedor, interface, decisão downstream, supervisão humana ou requisito aplicável. Incidentes, reclamações, drift, findings de segurança e controles que falharam também são gatilhos.

15. Requisitos, padrões, expectativas de stakeholders e critérios de risco

MAP deve identificar as restrições de decisão que MEASURE e MANAGE terão de aplicar.

15.1 Fontes de requisitos

Fontes relevantes podem incluir:

- leis e regulamentos;
- contratos e compromissos com clientes;
- política organizacional e apetite de risco;
- regras setoriais e deveres profissionais;
- padrões de segurança, privacidade, safety, acessibilidade e qualidade;
- restrições de propriedade intelectual e uso de dados;
- claims de produto e instruções ao usuário;
- negociação coletiva ou compromissos com a força de trabalho; e
- expectativas identificadas por engajamento com partes afetadas.

Mantenha requisitos vinculantes separados da orientação voluntária do framework. Confirme interpretações jurídicas por meio do processo jurídico autorizado da organização.

15.2 Critérios de aceitação

Traduza o contexto em critérios que possam apoiar uma decisão. Eles devem declarar:

- medida ou condição;
- limiar ou padrão qualitativo;
- população/cenário relevante;
- fonte de evidência;
- responsável e revisor;
- efeito bloqueante versus consultivo;
- autoridade de exceção; e
- expiração ou gatilho de reavaliação.

Evite escolher limiares apenas porque o sistema já os atende. Documente a justificativa baseada em consequências.

15.3 Objetivos conflitantes e tradeoffs

Características de confiabilidade podem interagir. Melhorar privacidade pode reduzir detalhes disponíveis para monitoramento; aumentar explicabilidade pode expor informação sensível de segurança; filtragem mais forte pode afetar utilidade ou acessibilidade. Registre tradeoff, partes afetadas, alternativas, evidência, autoridade de decisão e risco residual.

16. Pacote de evidências MAP, revisão e handoff para MEASURE

MAP está suficientemente completo para o próximo gate quando revisores conseguem identificar o que deve ser avaliado e por quê.

16.1 Pacote MAP mínimo

33. inventário atual e registro de responsabilidade;
34. declaração de propósito pretendido e uso proibido;
35. limite do sistema, ciclo de vida e implantação;
36. mapa de ator-tarefa e responsabilidades;

37. análise de partes afetadas e benefício-impacto;
38. mapa de dependências de dados/modelo/software/infraestrutura/fornecedor;
39. cenários de uso indevido, falha, segurança, privacidade, safety e resiliência;
40. registro de requisitos e critérios de aceitação;
41. registro de premissas, incerteza e lacunas de evidência;
42. nível inicial de risco e justificativa do caminho de revisão;
43. perguntas de medição e evidências planejadas; e
44. findings de revisão, discordância não resolvida e condições de aprovação.

16.2 Perguntas de revisão MAP

- O registro descreve o sistema/uso real em vez de um produto genérico?
- As partes afetadas vão além dos usuários diretos quando apropriado?
- Impactos positivos, danos e incerteza são considerados em conjunto?
- Dependências de sistema e fornecedores são específicas de versão?
- Uso indevido e falhas razoavelmente previsíveis estão incluídos?
- Requisitos e critérios de aceitação correspondem ao contexto?
- Lacunas de evidência estão visíveis?
- O nível de risco corresponde à consequência e à incerteza?
- Discordância material e questões em aberto são preservadas?
- Gatilhos de remapeamento estão explícitos?

16.3 Handoff para MEASURE

Converta cada cenário, afirmação ou requisito material em uma ou mais perguntas de avaliação. Para cada pergunta, identifique:

- a decisão que apoia;
- população e contexto relevantes;
- método e fonte de evidência;
- métrica ou rubrica qualitativa;
- limiar e expectativa de confiança;
- independência e competência necessárias;
- limitações e incerteza a reportar; e
- resultado que exigiria restrição, remediação ou parada.

Checkpoint da Parte 2: Os capítulos 9–16 estabelecem o contexto operacional e as perguntas de evidência. A Parte 3 constrói o programa MEASURE que testa afirmações, riscos e controles contra esse contexto.

17. Arquitetura da função MEASURE e governança de TEVV

MEASURE produz evidências relevantes para decisões sobre comportamento do sistema, risco, características de confiabilidade, controles e incerteza no contexto definido em MAP.

Teste, avaliação, verificação e validação são relacionados, mas não intercambiáveis:

- Teste: executa casos ou condições definidos e registra resultados observados.
- Avaliação: julga evidências em relação a critérios e necessidades de decisão.
- Verificação: determina se requisitos especificados ou expectativas de projeto foram atendidos.
- Validação: determina se o sistema é adequado ao propósito e contexto reais pretendidos.

Manual 03 memory graphic 10

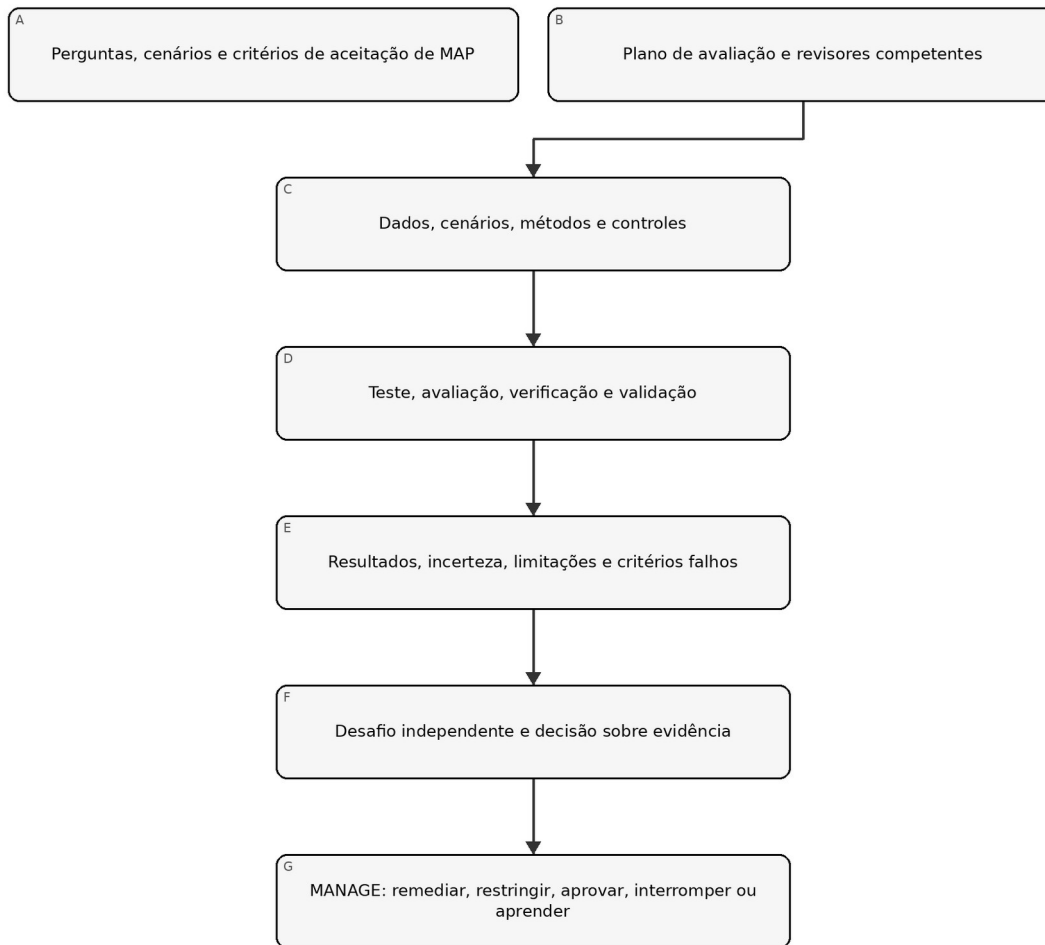


Figura 10. Gráfico de memória do capítulo

Explicação acessível: MAP fornece perguntas, cenários e critérios de aceitação. O plano de avaliação seleciona revisores competentes, dados, cenários e métodos. TEVV produz resultados com incertezas e limitações. Os revisores desafiam as evidências antes de a gestão usá-las para remediar, restringir, aprovar, interromper ou melhorar o sistema.

17.1 Princípios de medição

A avaliação deve ser:

- vinculada a uma decisão específica;
- representativa do contexto pretendido e razoavelmente previsível;
- vinculada à versão e reproduzível quando viável;
- proporcional à consequência e à incerteza;
- multidisciplinar para riscos sociotécnicos;
- suficientemente independente para proporcionar desafio efetivo;
- explícita sobre falhas e evidências ausentes;
- protegida contra manipulação de métricas e vazamento de benchmarks; e
- repetida após mudança material ou degradação da evidência.

17.2 Inventário de medição

Mantenha um registro de perguntas de avaliação. Cada registro deve identificar:

Campo	Conteúdo mínimo
Pergunta	Afirmção, requisito, cenário ou controle avaliado
Decisão	Aprovação, restrição, desenho de controle ou decisão de monitoramento suportada
Contexto	População, ambiente, fluxo de trabalho, usuário e versão
Método	Teste, análise, revisão, simulação, experimento, auditoria ou monitoramento
Crítérios	Limiar, rubrica, comparador e condição bloqueadora
Evidência	Dataset, conjunto de cenários, logs, revisão especializada ou outra fonte
Revisor	Executor, desafiador e competência necessária
Momento	Pré-liberação, periódico, contínuo, acionado por evento ou retirada
Limitação	Incerteza, exclusão ou risco de transferência conhecido
Resultado	Aprovado, condicional, falhou, inconclusivo ou não testado

17.3 Governança da medição

Defina quem pode aprovar métodos, limiares e exceções. Uma equipe que construiu o sistema pode executar testes, mas riscos materiais podem exigir validação ou desafio separado. A independência pode ser obtida por separação organizacional, par qualificado, especialista externo, revisor rotativo ou função de auditoria proporcional ao risco.

18. Plano de avaliação, métodos, dados, limiares e independência

Um resultado só é tão útil quanto a pergunta, o método, a evidência e a regra de decisão que o sustentam.

18.1 Conteúdo do plano de avaliação

O plano deve registrar:

45. sistema/uso, versão e contexto;
46. afirmações, cenários e requisitos derivados de MAP;
47. perguntas de avaliação e responsáveis pela decisão;
48. métodos e justificativa;
49. dados de teste, casos, cenários e amostragem;
50. populações e subgrupos relevantes;
51. linha de base, comparador e critérios de aceitação;
52. ambiente de execução e controles;
53. papéis, competência e independência dos revisores;
54. proteções de segurança, privacidade e safety para a própria avaliação;
55. método de análise de resultados e incerteza;
56. falhas bloqueadoras e escalonamento;
57. requisitos de reprodutibilidade e retenção de evidências; e
58. gatilhos de reteste e mudança.

18.2 Seleção de métodos

Use múltiplos métodos quando um único não puder capturar o risco:

- testes quantitativos de desempenho;
- revisão qualitativa baseada em rubricas;
- testes de cenário e modo de falha;
- simulação ou experimento controlado;
- avaliação de usabilidade e fatores humanos;
- análise de subgrupos e acessibilidade;

- avaliação de privacidade e segurança;
- testes adversariais ou red-team;
- revisão de código, arquitetura, dados e processos;
- validação de evidências de fornecedores;
- análise de logs operacionais, incidentes e reclamações; e
- revisão por especialistas ou partes afetadas.

18.3 Dados de avaliação

Verifique se os dados de avaliação são adequados à afirmação. Registre fonte, autoridade, população, período, coleta, pré-processamento, rotulagem, exclusões, qualidade, conteúdo sensível, versão e separação em relação a treinamento ou ajuste quando relevante.

Dados de teste podem criar riscos de privacidade, segurança, safety ou propriedade intelectual. Aplique controles de acesso, minimização, isolamento, retenção e exclusão.

18.4 Limiares e rubricas

Defina limiares antes de examinar os resultados finais quando prático. Explique:

- por que o limiar é aceitável para a consequência;
- se ele se aplica a médias, caudas, subgrupos ou eventos individuais;
- expectativa de confiança ou incerteza;
- exceções permitidas;
- condições bloqueadoras; e
- quem pode alterá-lo.

Médias podem ocultar falhas graves de subgrupos ou eventos raros. Inclua análise de distribuição, pior caso ou cenários específicos quando as consequências justificarem.

18.5 Integridade da avaliação

Proteja a avaliação contra:

- selecionar apenas casos favoráveis;
- alterar critérios depois de conhecer os resultados;
- contaminação ou memorização de benchmark;
- ajuste ao conjunto de teste sem confirmação independente;
- exclusão de falhas sem justificativa documentada;
- incompatibilidade de versão entre os sistemas testado e implantado;
- conflitos de interesse dos revisores; e
- relatar somente pontuações agregadas sem limitações.

19. Validade, confiabilidade e avaliação do desempenho da tarefa

Evidências de desempenho devem refletir a tarefa real, não apenas um benchmark conveniente.

19.1 Decomposição de afirmações

Decomponha afirmações amplas em propriedades observáveis. “Preciso” pode incluir:

- classificação ou previsão correta;
- completude das informações necessárias;
- calibração ou comportamento de confiança;
- consistência entre execuções repetidas;
- estabilidade sob variação esperada;
- tempestividade e latência;
- abstenção apropriada ou sinalização de incerteza; e
- comportamento de erro aceitável entre populações relevantes.

19.2 Validade

Pergunte se a avaliação realmente sustenta a inferência pretendida:

- O teste representa a tarefa e a população?
- A referência ou ground truth é confiável?
- Rótulos e rubricas são suficientemente confiáveis?
- Fatores de confusão importantes estão controlados ou relatados?
- O desempenho offline se transfere ao fluxo de trabalho?
- A interação humana altera o resultado?
- Ações downstream estão incluídas?

19.3 Confiabilidade

Avalie consistência entre:

- execuções repetidas;
- sementes ou execuções não determinísticas;
- tempo e carga operacional;
- dispositivos, regiões ou ambientes;
- variação relevante de entradas;
- revisores ou anotadores; e
- versões de modelo/provedor.

Para sistemas generativos, use múltiplas amostras e revisão estruturada em vez de apresentar uma saída favorável como evidência.

19.4 Análise de erros

Não pare em uma única pontuação. Caracterize:

- tipos de erro e severidade;
- consequências de falsos positivos e falsos negativos;
- comportamento de cauda e eventos raros;
- variação entre subgrupos e interseções quando relevante;
- comportamento de abstenção e escalonamento;
- detectabilidade de erros pelos usuários;
- amplificação downstream; e
- condições operacionais associadas à falha.

19.5 Avaliação comparativa

Compare com o processo atual, um sistema mais simples, desempenho humano qualificado ou outra linha de base razoável. Registre diferenças de custo, tempo, acesso, qualidade, safety e carga. A pergunta relevante frequentemente é se o processo habilitado por IA melhora o sistema de decisão como um todo, não se o modelo supera uma métrica isolada.

20. Avaliação de safety, cibersegurança, robustez e resiliência

Sistemas de IA materiais exigem evidências sobre comportamento sob estresse, ataque, falha e recuperação.

20.1 Modelo de avaliação

Manual 03 memory graphic 11

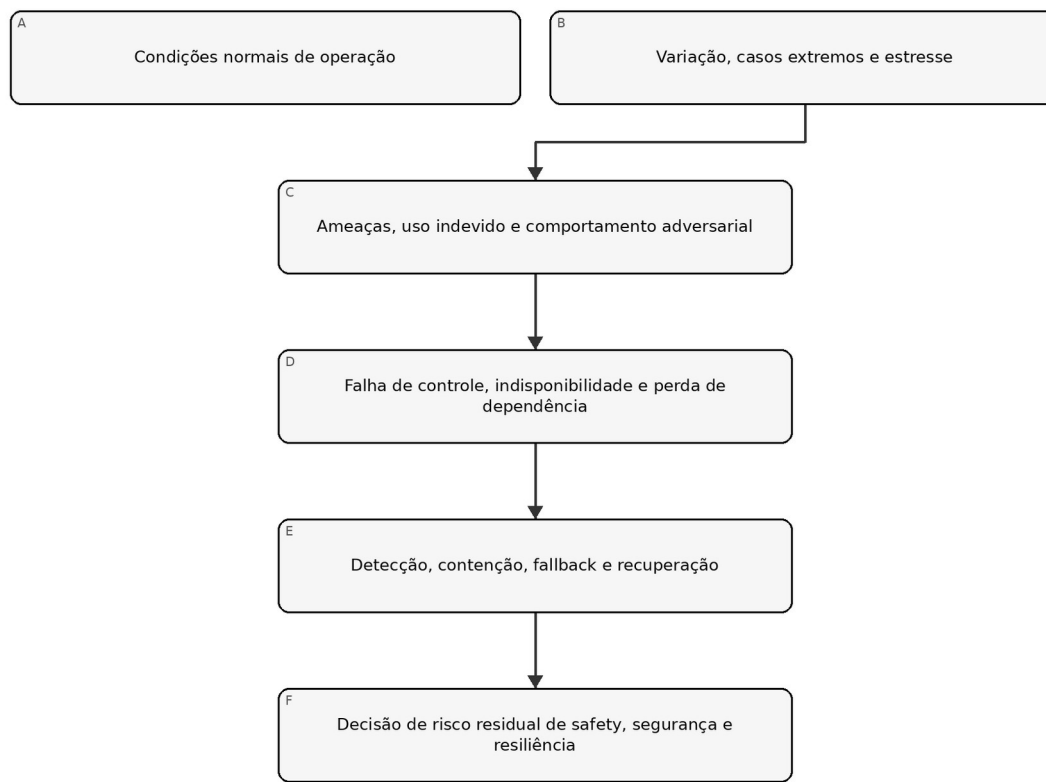


Figura 11. Gráfico de memória do capítulo

Explicação acessível: A avaliação começa com operação normal, amplia-se para casos extremos e estresse e então testa ameaças e uso indevido. Também examina falha de controles ou dependências e se a organização consegue detectar, conter, usar alternativas e recuperar antes de decidir qual risco residual permanece.

20.2 Avaliação de safety

Conforme relevante, avalie:

- perigos e ações inseguras;
- uso e uso indevido previsíveis;
- interação insegura com pessoas ou sistemas físicos;
- detecção de falha e estado seguro;
- tempo de intervenção humana;
- parada de emergência e alternativa manual;
- consequências em cascata; e
- validação de recuperação.

Use expertise especializada do domínio de safety quando as consequências forem além de falha comum de software.

20.3 Avaliação de cibersegurança

Inclua o sistema de IA completo. Considere:

- envenenamento de dados e entradas maliciosas;
- evasão e exemplos adversariais;

- prompt injection e indirect prompt injection;
- agência excessiva e uso indevido de ferramentas;
- extração de modelo, prompts, dados ou segredos;
- tratamento inseguro de saídas;
- fraquezas de controle de acesso e identidade;
- comprometimento de dependências e cadeia de suprimentos de software;
- negação de serviço e exaustão de recursos;
- bypass de logging ou monitoramento; e
- alteração não autorizada de modelo/configuração.

Use ambientes controlados e autorização explícita para testes adversariais. Não exponha dados sensíveis reais nem sistemas de produção desnecessariamente.

20.4 Robustez

Teste o comportamento sob variação esperada e perturbações plausíveis, incluindo entradas ruidosas, incompletas, ambíguas, fora de distribuição, multilíngues ou manipuladas intencionalmente quando relevante. Robustez é específica ao contexto; resistência a um teste não demonstra robustez ampla.

20.5 Resiliência e recuperação

Exercite:

- indisponibilidade de fornecedor ou modelo;
- degradação de latência ou capacidade;
- falha de filtro de safety;
- dados corrompidos ou indisponíveis;
- perda de logging ou monitoramento;
- revogação de credenciais;
- rollback para uma versão conhecida;
- operação degradada ou manual;
- comunicação de incidentes; e
- validação de restauração.

Registre tempo de recuperação, ponto de recuperação, carga de trabalho manual, reconciliação de dados e limitações residuais.

21. Evidência de responsabilização, transparência, explicabilidade e interpretabilidade

A informação só é útil quando permite à pessoa pretendida compreender, agir, questionar ou buscar reparação.

21.1 Transparência específica para a audiência

Identifique o que cada audiência precisa:

Audiência	Necessidade típica
Usuário/operador	Propósito, uso correto, limites, verificação, escalonamento e instruções de parada
Pessoa afetada	Envolvimento de IA, consequência relevante, explicação acessível e caminho de correção/recurso
Proprietário/gestão	Risco, evidência, falhas, risco residual, incidentes e condições de decisão
Equipe técnica	Versões, dados, métodos, limitações, monitoramento e detalhes de mudança
Revisor/auditor	Evidência rastreável, aprovações, critérios, papéis de trabalho e operação de controles
Regulador/cliente	Informação exigida pela autoridade aplicável ou contrato, sujeita a revisão jurídica

21.2 Explicabilidade e interpretabilidade

Avalie se o método de explicação é apropriado ao modelo, decisão, audiência e consequência. Teste:

- fidelidade ao comportamento real do sistema;
- estabilidade e consistência;
- completude para a necessidade de decisão;
- compreensibilidade e acessibilidade;
- capacidade de ação;
- resistência a apresentação enganosa; e
- compensações de segurança/privacidade.

Uma explicação que parece plausível, mas não reflete o sistema, é pior que uma limitação declarada honestamente.

21.3 Rastreabilidade e responsabilização

Confirme que a organização consegue reconstruir:

- qual sistema/versão atuou;
- entrada e contexto relevantes, sujeitos a limites de privacidade;
- saída ou ação;
- revisão humana ou override;
- política aplicável e estado do controle;
- autoridade de decisão;
- vínculo com incidente ou reclamação; e
- correção ou mudança posterior.

22. Avaliação de privacidade e viés prejudicial

Riscos relacionados a privacidade e equidade exigem contexto, análise de partes afetadas e mais de uma métrica agregada.

22.1 Avaliação de privacidade

Avalie todo o ciclo de vida dos dados:

- autoridade e propósito;
- minimização e necessidade;
- aviso e escolha significativa quando aplicável;
- tratamento de dados sensíveis;
- exposição em treinamento, retrieval, prompts e saídas;
- risco de inferência ou reidentificação;
- retenção e exclusão;
- acesso, compartilhamento e subprocessadores;
- privacidade de monitoramento/logging; e
- processos de correção, acesso ou outros direitos aplicáveis.

Testes técnicos podem incluir análise de leakage, memorização, extração ou inferência conforme relevante, mas devem ser combinados com evidências de governança e processo.

22.2 Avaliação de viés prejudicial

Comece pelos danos mapeados e grupos afetados. Determine:

- quais resultados ou erros importam;
- quais grupos e interseções exigem análise;
- qual comparação é significativa;
- se os dados sustentam a inferência;
- se a métrica reflete o processo real de decisão;
- se a revisão humana mitiga ou amplifica o efeito;
- qual limiar ou julgamento qualitativo se aplica; e
- qual remédio existe.

Nenhuma métrica de equidade é universalmente correta. Registre justificativa, compensações, revisão jurídica quando necessária, limitações e risco residual.

22.3 Evidência de processo e resultado

Revise ambos:

- evidência de processo: participação, governança de dados, escolhas de projeto, revisão, documentação e tratamento de reclamações; e
- evidência de resultado: padrões de desempenho, erro, alocação, carga ou impacto no contexto real.

22.4 Acessibilidade e idioma

Avalie se interfaces, avisos, explicações, suporte e caminhos de recurso funcionam para necessidades relevantes de deficiência, alfabetização, idioma e acesso à tecnologia. Defeitos de acessibilidade podem criar exclusão sistemática mesmo quando o desempenho do modelo parece aceitável.

23. Fatores humanos, supervisão e avaliação de partes afetadas

O desempenho da equipe humano-IA pode diferir materialmente do desempenho do modelo medido isoladamente.

23.1 Teste de eficácia da supervisão

Avalie se a pessoa responsável pela supervisão:

- reconhece quando IA está envolvida;
- entende propósito e limitações;
- tem informação e tempo suficientes;
- consegue identificar erros importantes;
- pode discordar sem penalidade;
- pode corrigir, fazer override ou interromper;
- usa corretamente escalonamento e fallback; e
- deixa um registro auditável.

Meça viés de automação, complacência, carga de trabalho, fadiga de alertas, degradação de habilidades e diferenças entre níveis de experiência.

23.2 Avaliação do fluxo humano-IA

Compare, pelo menos quando material:

- linha de base apenas humana;
- resultado apenas de IA para compreensão diagnóstica;
- humano com assistência de IA;
- diferentes desenhos de interface ou explicação; e
- operação degradada ou fallback.

O modelo operacional aprovado deve ser o que foi efetivamente avaliado.

23.3 Avaliação de partes afetadas

Métodos podem incluir testes de usabilidade acessíveis, entrevistas, análise de reclamações, pilotos controlados, revisão de jornada, avaliação participativa ou painéis de especialistas do domínio. Proteja participantes e informações sensíveis e evite colocar inteiramente sobre pessoas afetadas o ônus de provar dano.

23.4 Recursos, correção e reparação

Teste se uma pessoa pode:

- reconhecer uma decisão ou saída relevante;
- obter informação compreensível;
- apresentar correção ou contestação;

- alcançar uma pessoa competente;
- receber tratamento oportuno;
- evitar propagação repetida quando apropriado; e
- obter o remédio autorizado por política ou lei.

24. Incerteza, limitações, revisão de resultados e pacote de evidências MEASURE

Responsáveis por decisões precisam de um relato fiel do que a evidência sustenta, do que não sustenta e de quão rapidamente ela pode se tornar obsoleta.

24.1 Registro de resultados

Para cada avaliação material, retenha:

- ID da avaliação e pergunta MAP vinculada;
- versões de sistema, modelo, dados, prompt/configuração e software;
- método, ambiente e data de execução;
- dataset/conjunto de cenários e amostragem;
- critérios e limiares predefinidos;
- executor, revisor e competência;
- resultados detalhados e resumidos;
- falhas, exclusões e anomalias;
- incerteza e confiança;
- limitações e condições de transferência;
- tratamento de segurança/privacidade;
- achados e remediação;
- resultados de reteste; e
- disposição da gestão.

24.2 Declaração de incerteza

Declare:

59. o que é conhecido com suporte razoável;
60. o que permanece incerto;
61. por que a incerteza existe;
62. como a incerteza pode afetar pessoas ou decisões;
63. controles ou limites de implantação usados por causa dela;
64. monitoramento ou pesquisa planejados; e
65. quem aceitou a incerteza restante e até quando.

24.3 Classificação de resultados

- **Aprovado:** a evidência atende aos critérios definidos no contexto testado.
- **Condicional:** os critérios são atendidos apenas sob restrições documentadas ou controles compensatórios.
- **Falhou:** um ou mais critérios bloqueadores não são atendidos.
- **Inconclusivo:** a evidência é insuficiente ou inconsistente para a decisão.
- **Não testado:** a pergunta permanece aberta e não pode ser representada como satisfeita.

Falhe de forma fechada quando um resultado obrigatório tiver falhado, for inconclusivo, estiver ausente, incompatível com a versão, expirado ou invalidado por mudança material.

24.4 Revisão de evidências

Manual 03 memory graphic 12

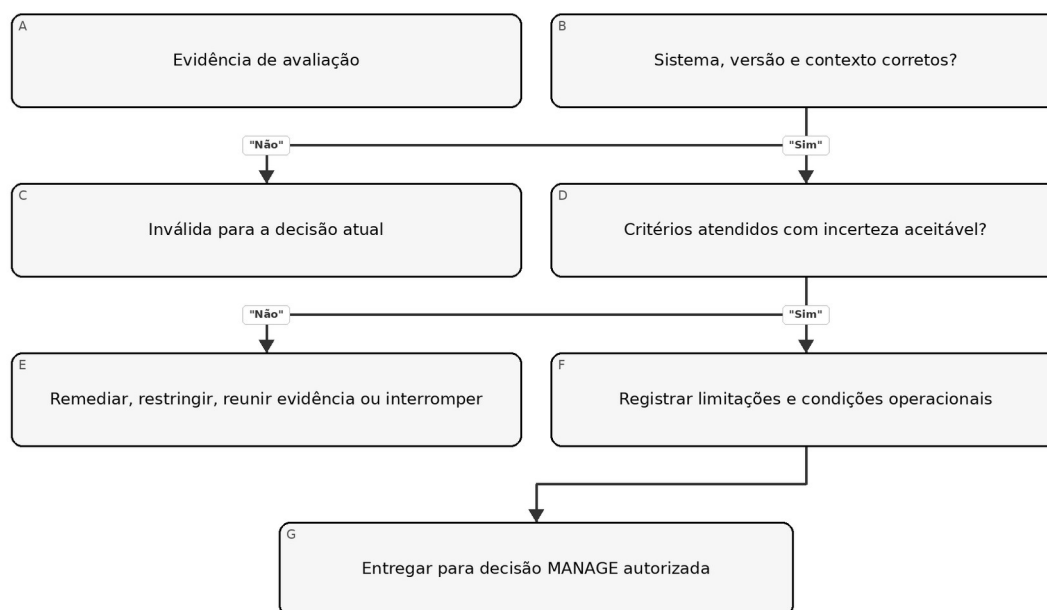


Figura 12. Gráfico de memória do capítulo

Explicação acessível: A revisão primeiro confirma que a evidência se aplica ao sistema, versão e contexto corretos. Caso contrário, é inválida. Se critérios ou incerteza forem inaceitáveis, a organização remedia, restringe, reúne mais evidências ou interrompe. Evidência aceitável é entregue a uma decisão de gestão autorizada com limitações e condições preservadas.

24.5 Pacote mínimo de MEASURE

66. plano de avaliação aprovado;
67. matriz de perguntas para métodos;
68. datasets controlados e manifestos de cenários;
69. registro de ambiente e versão;
70. resultados executados e análise;
71. evidência de características de confiabilidade relevantes ao contexto;
72. avaliação humana/de partes afetadas quando necessária;
73. itens falhos, inconclusivos e não testados;
74. declaração de incerteza e limitações;
75. desafio do revisor, achados e remediação;
76. evidência de reteste; e
77. resumo pronto para decisão vinculado a papéis de trabalho detalhados.

Checkpoint Parte 3: Os capítulos 17–24 criam evidências sem exagerá-las. A Parte 4 usa essas evidências para priorizar, tratar, decidir, monitorar, responder e melhorar por meio de MANAGE.

25. Arquitetura da função MANAGE e priorização de risco

MANAGE converte o contexto mapeado e a evidência medida em tratamento priorizado, decisões responsáveis, controles operacionais e melhoria.

Manual 03 memory graphic 13

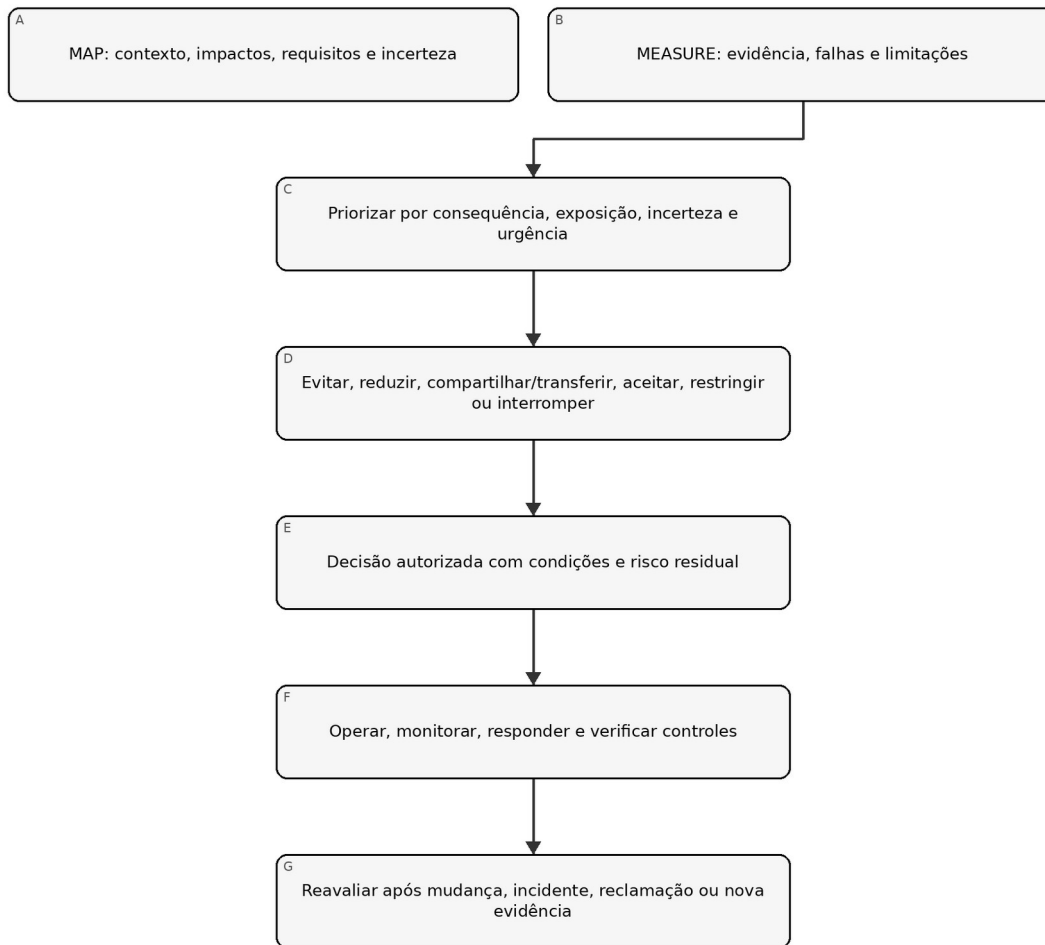


Figura 13. Gráfico de memória do capítulo

Explicação acessível: A gestão combina o contexto de MAP com a evidência de MEASURE, prioriza o risco, seleciona o tratamento e registra uma decisão autorizada com condições e risco residual. A operação monitora e verifica controles. Mudanças e sinais do mundo real acionam nova avaliação.

25.1 Registro de priorização

Priorize usando mais que uma pontuação genérica. Registre:

- consequência plausível e reversibilidade;
- população afetada, vulnerabilidade e escala;
- exposição, frequência e duração;
- probabilidade quando houver suporte;
- incerteza e qualidade da evidência;
- força do controle e detectabilidade;
- urgência, incluindo incidentes ativos ou prazos legais;
- risco de modo comum ou concentração;
- compensações entre oportunidade e benefício; e
- dependências entre riscos.

Alta incerteza pode justificar controles mais fortes ou um piloto mais restrito mesmo quando a probabilidade for desconhecida.

25.2 Visão de portfólio

Agregue riscos de IA entre sistemas sem perder responsabilização no nível do sistema. A gestão deve identificar:

- múltiplos usos dependentes do mesmo modelo/provedor;
- falhas repetidas de controles;
- efeitos cumulativos sobre a mesma população;
- capacidade escassa de supervisão ou validação;
- risco correlacionado de cibersegurança, privacidade ou operação;
- exceções e decisões de risco residual próximas da expiração; e
- sistemas cuja autonomia ou escala combinada exceda premissas originais.

25.3 Cadência de decisão

Use revisão orientada por eventos além de calendários. Revise a prioridade quando surgir mudança material, incidente, reclamação, falha de avaliação, aviso de fornecedor, desenvolvimento jurídico, mudança de tolerância ao risco ou nova população afetada.

26. Tratamento de risco, controles, responsabilidade e planejamento de ações

O tratamento deve alterar exposição real, comportamento ou capacidade de recuperação, não apenas criar documentação.

26.1 Opções de tratamento

- Evitar: não iniciar, remover uma função ou retirar o uso.
- Reduzir: alterar propósito, projeto, dados, modelo, autonomia, população, processo ou controles.
- Compartilhar/transferir: alocar obrigações definidas por contrato ou seguro, mantendo a responsabilização não transferível.
- Aceitar: autorizar risco residual dentro de autoridade e condições documentadas.
- Pilotar/restringir: limitar geografia, população, usuários, dados, autonomia, duração ou volume para reunir evidências com segurança.
- Interromper/rollback: suspender a operação ou retornar a um estado seguro conhecido.

26.2 Registro de desenho de controle

Campo	Conteúdo mínimo
Risco/cenário	Causa-evento-consequência mapeados e partes afetadas
Objetivo	Exposição, falha ou consequência tratada pelo controle
Controle	Atividade preventiva, detectiva, corretiva ou de recuperação
Proprietário/operador	Proprietário responsável e pessoa/sistema que o executa
Gatilho/frequência	Contínuo, por transação, liberação, periódico ou orientado por evento
Evidência	Registro que comprova desenho e operação
Limiar	Condição que provoca ação ou escalonamento
Dependência	Dados, ferramenta, fornecedor, revisor ou infraestrutura necessária
Limitação	Lacuna ou modo de falha conhecido
Teste	Como eficácia de desenho e operacional são avaliadas
Risco residual	O que permanece após o controle

26.3 Hierarquia de controles

Prefira controles que removam ou restrinjam o risco na origem antes de depender apenas de usuários para detectar erros. Conforme o contexto:

78. eliminar o uso ou capacidade perigosa;
79. reduzir escopo, autonomia, dados ou acesso;
80. redesenhar arquitetura, modelo, fluxo de trabalho ou interface;
81. implementar controles técnicos e de processo;
82. adicionar supervisão humana competente e verificação independente;
83. adicionar avisos, instruções e treinamento; e
84. monitorar, responder e fornecer reparação.

Treinamento e disclaimers raramente são controles suficientes para comportamento de sistemas de alta consequência.

26.4 Plano de ação

Todo item de remediação deve ter responsável, data de vencimento, severidade, dependência, critérios de aceitação, evidência, método de reteste e caminho de escalonamento. Uma data de vencimento não reduz o risco atual; restrições provisórias podem ser necessárias até a remediação ser verificada.

27. Decisões de risco residual, exceções e aceitação responsável

Risco residual é uma decisão sobre a exposição restante após evidências e controles, não um rótulo gerado por ferramenta de pontuação.

27.1 Registro de aceitação

Registre:

- sistema/uso e versão exatos;
- escopo da decisão, população, geografia e duração;
- riscos, benefícios e partes afetadas relevantes;
- evidências revisadas e incerteza não resolvida;
- controles e condições operacionais;
- itens falhos, inconclusivos ou não testados;
- justificativa de risco residual;
- autoridade de decisão e competência;
- aprovação, aprovação condicional, restrição ou rejeição;
- expiração e data de revisão;
- gatilhos automáticos de reavaliação/interrupção; e
- divergência ou visão minoritária.

27.2 Níveis de autoridade

Alinhe a autoridade de aceitação à consequência. Risco baixo e delimitado pode ser aceito pelo proprietário responsável dentro da política. Risco moderado pode exigir aprovação multifuncional. Risco de alta consequência, regulado, sensível a safety ou de portfólio pode exigir autoridade executiva ou designada pelo conselho e desafio independente.

Ninguém deve aceitar risco em nome das partes afetadas apenas porque a organização se beneficia. Obrigações legais e não transferíveis permanecem vinculantes.

27.3 Exceções

Uma exceção deve ser:

- estreita e limitada no tempo;
- aprovada por pessoas autorizadas;
- explícita sobre o requisito não atendido;
- apoiada por análise de risco;
- acompanhada de controles compensatórios ou restrições;

- monitorada;
- visível às funções de assegurarão; e
- expirada automaticamente, salvo renovação por nova decisão.

27.4 Verificação da qualidade da decisão

Rejeite ou devolva uma decisão se a evidência estiver ausente, incompatível com a versão, expirada, invalidada por mudança material, internamente inconsistente ou incapaz de sustentar o contexto alegado. “Urgência do negócio” deve ser registrada como fator, não usada para apagar risco.

28. Implantação, liberação, restrição, interrupção, rollback e retirada

A liberação é uma decisão de risco baseada em evidências para uma configuração exata, não o fim da gestão de riscos.

28.1 Gate de liberação

Manual 03 memory graphic 14

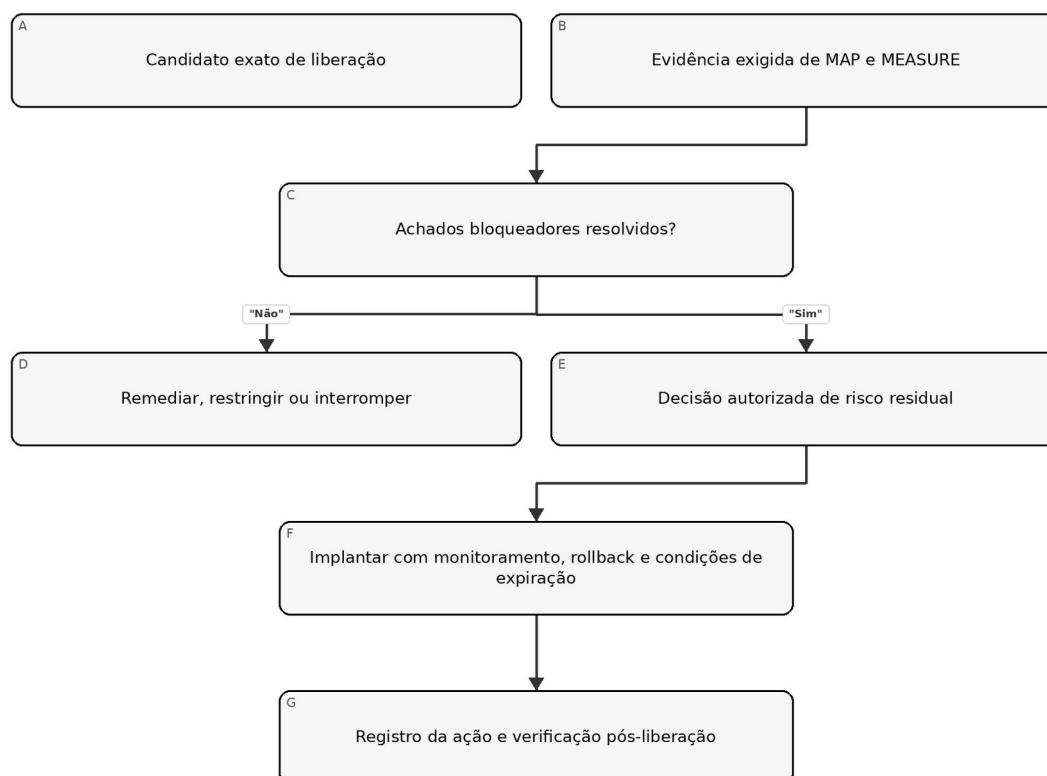


Figura 14. Gráfico de memória do capítulo

Explicação acessível: O gate de liberação identifica o candidato exato e as evidências exigidas. Achados bloqueadores levam a remediação, restrição ou interrupção. Quando a evidência sustenta a decisão, uma pessoa autorizada aceita o risco residual e a implantação ocorre com condições de monitoramento e rollback. A liberação e o acompanhamento ficam registrados.

28.2 Evidência mínima de liberação

- propósito e contexto aprovados;
- nível de risco atual;
- versões exatas de modelo, dados, prompt/configuração, software e dependências;
- resultados de avaliação exigidos e limitações;
- revisões de cibersegurança, privacidade, safety, acessibilidade e domínio conforme aplicável;
- evidência do fornecedor e condições contratuais;
- instruções ao usuário e à supervisão;
- preparação para monitoramento e incidentes;
- teste de interrupção, rollback, fallback e recuperação;
- achados não resolvidos e condições aceitas;
- aprovação de risco residual; e
- registro de liberação e identificadores de checksum/versão.

28.3 Implantação progressiva

Use liberação em estágios ou canary, populações limitadas, autonomia menor, limites de taxa, gates de aprovação, processo humano paralelo ou avaliação shadow quando isso reduzir a incerteza sem expor pessoas a risco inaceitável.

28.4 Interrupção e rollback

Defina gatilhos objetivos, autoridade e capacidade técnica. Exemplos:

- dano grave ou dano iminente crível;
- comprometimento de segurança ou exposição de dados sensíveis;
- degradação material de desempenho ou de subgrupos;
- saídas prejudiciais ou proibidas repetidas;
- perda de supervisão humana exigida;
- evidência exigida inválida ou ausente;
- mudança não aprovada de fornecedor/modelo;
- falha de monitoramento ou logging de um controle crítico; e
- proibição legal ou contratual vinculante.

Teste interrupção e rollback antes de depender deles. Confirme revogação de identidade, ações em fila, reconciliação downstream, comunicações e validação de restauração.

28.5 Retirada

A retirada deve tratar retenção/exclusão de dados e registros, acesso a modelo e credenciais, integrações, comunicação aos usuários, encerramento de fornecedor, decisões pendentes, legal hold, transferência de conhecimento, arquivamento, encerramento do monitoramento e confirmação de que o sistema não atua mais.

29. Monitoramento, deriva, incidentes, reclamações, recursos e ação corretiva

Evidência operacional determina se premissas e controles permanecem válidos após a liberação.

29.1 Desenho de monitoramento

Para cada medida, defina:

- pergunta e risco tratado;
- fonte de dados e limite de privacidade;
- população e versão;
- cálculo ou rubrica;
- linha de base e limiar;
- proprietário e revisor;
- frequência ou latência;
- ação quando o limiar for excedido;
- limitação de falso positivo/falso negativo; e

- retenção de evidência.

Monitore comportamento do sistema, interação humana, controles, resultados que afetam pessoas, mudanças de fornecedores e o próprio sistema de monitoramento.

29.2 Deriva e degradação

Diferencie mudanças em dados de entrada, população, conceito/relação, comportamento do modelo, fluxo de trabalho, usuários, ambiente e resultado. Uma métrica pode permanecer estável enquanto a consequência muda; combine sinais quantitativos com incidentes, reclamações, overrides e revisão de domínio.

29.3 Processo de incidentes

Manual 03 memory graphic 15

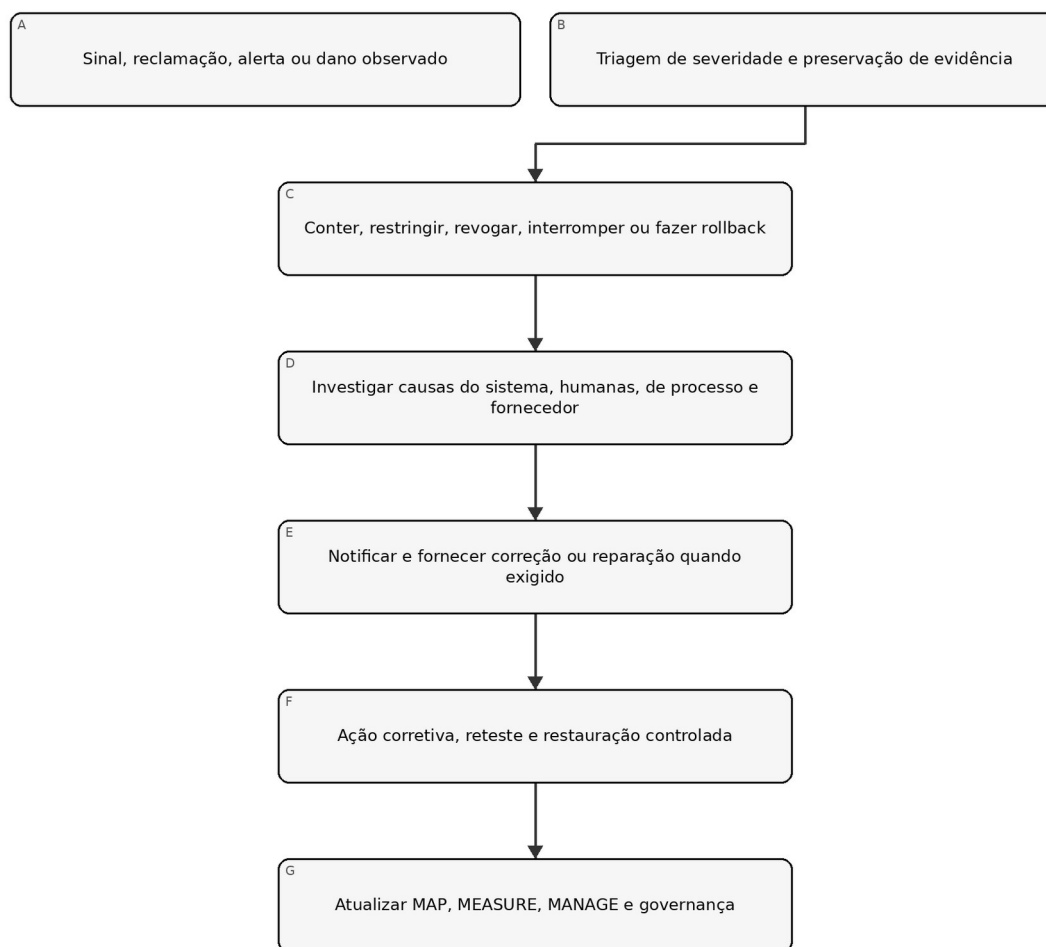


Figura 15. Gráfico de memória do capítulo

Explicação acessível: Um incidente começa com sinal ou reclamação, seguido de triagem e preservação de evidências. A organização contém o problema, investiga causas técnicas e organizacionais, fornece notificação ou reparação exigida, verifica ação corretiva e atualiza todo o ciclo de gestão de riscos.

29.4 Reclamações, recursos e reparação

Trate reclamações como evidência de risco, não apenas tickets de atendimento. Vincule-as à versão e ao contexto do sistema, proteja reclamantes, ofereça canais acessíveis, impeça retaliação, defina níveis de serviço, permita revisão humana competente e acompanhe padrões repetidos.

29.5 Ação corretiva

Separe correção imediata de ação corretiva de causa raiz. Registre:

- problema e consequência;
- contenção/correção;
- análise de causa em tecnologia, pessoas, processo e governança;
- extensão sistêmica;
- responsável pela ação e prazo;
- verificação de implementação;
- reteste de eficácia;
- monitoramento de recorrência; e
- atualizações de sistemas relacionados, políticas, treinamento e controles de fornecedores.

30. Mudanças, fornecedores, IA generativa e governança de sistemas agênticos

Mudança material invalida premissas e evidências afetadas até que o impacto seja avaliado.

30.1 Classes de mudança

Revise mudanças em:

- propósito ou limite de uso proibido;
- população, geografia, idioma ou escala;
- fonte de dados, característica, retenção ou transformação;
- modelo, fornecedor, versão, fine-tuning ou prompt;
- software, ferramenta, integração ou permissão;
- autonomia ou ação downstream;
- interface, aviso ou supervisão humana;
- fornecedor/subprocessador e contrato;
- monitoramento e logging; e
- requisito aplicável ou tolerância ao risco.

Classifique mudanças como não materiais, materiais com revisão delimitada ou materiais que exigem reavaliação completa. Preserve justificativa e revisor.

30.2 Controle de mudanças de fornecedor

Exija notificação quando viável, mas assuma que fornecedores podem alterar comportamento sem aviso completo. Use fixação de versão, testes de regressão, monitoramento, direitos contratuais, atualização de evidências, fallback e planejamento de saída proporcional à dependência.

30.3 Integração do perfil de IA generativa

Quando IA generativa estiver no escopo, aplique NIST AI 600-1 como perfil complementar ao processo geral do AI RMF. Avalie famílias de risco GenAI e ações de perfil aplicáveis sem tratar toda ação como universalmente exigida.

No mínimo, considere:

- confabulação e conteúdo sem suporte;
- conteúdo perigoso, odioso ou abusivo;
- preocupações de privacidade de dados e propriedade intelectual;
- integridade e proveniência da informação;
- cibersegurança e ataques a prompts/ferramentas;
- dependência humana excessiva e efeitos emocionais ou sociais;

- viés prejudicial e homogeneização;
- habilitação de uso indevido e abuso em escala;
- efeitos ambientais e de recursos quando materiais;
- risco da cadeia de valor e integração de componentes; e
- limitações de avaliação.

O Manual 04 fornece implementação mais profunda do NIST AI 600-1.

30.4 Sistemas agênticos

Para agentes autônomos ou que usam ferramentas, implemente e teste:

- identidades restritas e privilégio mínimo;
- allowlists de ferramentas e ações proibidas;
- limites de transação, tempo, taxa e recursos;
- confirmação humana para ações consequenciais;
- limites de confiança de entrada/conteúdo;
- isolamento de ambiente;
- rastros completos de ações;
- controles de memória e retenção;
- revogação determinística e parada de emergência;
- rollback e reconciliação downstream; e
- responsabilidade explícita por decisões delegadas.

31. Métricas, asseguração, auditoria interna e melhoria contínua

Asseguração pergunta se governança e controles estão desenhados e operando eficazmente; não certifica que o risco foi eliminado.

31.1 Métricas de gestão

Use medidas vinculadas a decisões, como:

- usos ativos de IA com proprietário, nível e aprovação atuais;
- sistemas materiais vinculados a evidência de avaliação da versão implantada;
- falhas de alta severidade e idade de remediação;
- exceções e decisões de risco residual expiradas;
- incidentes, reclamações, recursos, overrides e recorrência;
- violações de limiar e tempo de resposta;
- evidência de fornecedor e mudanças não revisadas;
- retestes de eficácia de ação corretiva; e
- sistemas restritos, interrompidos ou redesenhados porque a evidência era inadequada.

Evite recompensar volume de documentos ou suprimir relato de incidentes.

31.2 Asseguração de controles

Teste ambos:

- eficácia de desenho: o controle, se operado conforme desenhado, trata o risco no contexto; e
- eficácia operacional: o controle realmente operou para a população e período exigidos, produziu evidência, detectou exceções e causou a ação necessária.

31.3 Auditoria interna

Um programa de auditoria deve definir escopo baseado em risco, critérios, competência, independência, amostragem, evidência, achados, reporte e acompanhamento. Auditores não devem auditar o próprio trabalho sem salvaguardas. Preserve a distinção entre auditoria interna, avaliação técnica, revisão de compliance, certificação e exame regulatório.

31.4 Classificação de achados

Classifique achados com base em consequência, extensão sistêmica, falha de controle, recorrência, evidência e urgência. Todo achado deve identificar critério, condição, evidência, impacto/risco, responsável, ação, prazo e teste de encerramento.

31.5 Ciclo de aprendizagem

Use incidentes, near misses, reclamações, auditorias, eventos de fornecedores e controles bem-sucedidos para atualizar inventário, critérios de risco, cenários, métodos de avaliação, limiares, treinamento, padrões de projeto e decisões de portfólio.

32. Roteiros de implementação, maturidade, perfis e revisão do framework

Organizações devem começar com um mínimo controlado e adicionar profundidade quando risco, complexidade e evidência exigirem.

32.1 Roteiro Essencial

Primeiros 30 dias

- designar liderança responsável por risco de IA;
- emitir regras provisórias de usos aprovados/proibidos;
- iniciar descoberta e inventário de IA;
- definir método simples de roteamento de risco;
- identificar usos materiais existentes;
- estabelecer contatos para incidentes e interrupção; e
- selecionar pequeno conjunto de modelos de evidência.

Dias 31–90

- concluir contexto e avaliação mínima para usos materiais;
- atribuir autoridade de risco residual;
- implementar verificações de fornecedores e mudanças;
- documentar instruções de usuário/supervisão;
- definir limiares de monitoramento; e
- remediar ou restringir usos sem evidência sustentável.

Meses 4–12

- reconciliar o inventário periodicamente;
- testar controles e ações corretivas;
- melhorar tratamento de incidentes/reclamações;
- construir métricas de gestão;
- executar revisão interna baseada em risco; e
- atualizar o perfil-alvo.

32.2 Roteiro Structured

Adicione governança formal, gates multifuncionais do ciclo de vida, TEVV controlado, versão/linhagem, evidência de fornecedor, revisão de privacidade/cibersegurança/acessibilidade/domínio, métricas operacionais, revisão periódica de gestão, auditoria interna e retenção controlada de evidências.

32.3 Roteiro Enhanced

Adicione supervisão executiva/do conselho, validação independente, engajamento de partes afetadas, avaliação adversarial e de estresse, monitoramento contínuo de riscos-chave, interrupção/rollback ensaiados, análise de concentração do portfólio, vigilância reforçada de fornecedores e expiração formal de risco residual.

32.4 Modelo de maturidade

Nível	Estado observável
0 — Não controlado	Uso de IA é desconhecido ou não gerenciado; responsabilidade e evidência estão ausentes
1 — Inicial	Existem inventário básico, política, responsável e revisão caso a caso
2 — Repetível	Roteamento de risco, gates do ciclo de vida, avaliação e evidência são usados consistentemente
3 — Medido	Métricas operacionais, testes de controles, revisão de fornecedores/mudanças e decisões de gestão estão vinculados
4 — Adaptativo	Incidentes, evidência de partes afetadas, risco de portfólio e asseguração impulsionam sistematicamente a melhoria

Maturidade não é certificação. Um processo de Nível 4 ainda pode tomar uma decisão ruim sobre um sistema, e uma organização pequena pode operar controles fortes sem burocracia elaborada.

32.5 Perfis atual e alvo

Crie um perfil atual descrevendo resultados e evidências reais e um perfil-alvo descrevendo resultados desejados com base em risco e obrigações. O plano de lacunas deve identificar prioridade, responsável, recursos, dependências, data, evidência e restrição provisória.

32.6 Protocolo de revisão do framework

Quando o NIST publicar um AI RMF revisado:

85. congele o candidato de liberação atual do Manual 03;
86. verifique a publicação oficial final e a versão;
87. compare funções, categorias, subcategorias, terminologia e orientação;
88. classifique impactos em capítulos, modelos, gráficos, perfis e crosswalks;
89. atualize primeiro a fonte controlada em inglês;
90. reabra revisões de fonte e técnicas afetadas;
91. relocalize o significado alterado por meio de localização controlada revisada por humanos;
92. regenere artefatos DOCX/PDF e repita QA de acessibilidade, visual e segurança; e
93. publique registro de mudança versionado sem sobrescrever silenciosamente a linha de base anterior.

32.7 Limite final de implementação

Implementar este manual pode fortalecer governança de risco e evidências. Não demonstra que um sistema de IA é confiável, não elimina dano, não satisfaz todas as leis, não estabelece conformidade com ISO/IEC 42001, não cria certificação nem constitui opinião de auditoria. A organização permanece responsável pelo sistema real, contexto, obrigações, decisões e efeitos.

Checkpoint Parte 4: Os capítulos 25–32 concluem o ciclo operacional GOVERN–MAP–MEASURE–MANAGE e o conectam a implantação, operações, incidentes, asseguração, roteiros e revisão controlada do framework.